Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА
Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)

Коновалова Дмитрия Яковлевича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Генерация сообщений об ошибке ICMP»

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 88 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (Р.С. Лопатин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ Д.Я. Коновалов
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности

Кафедра Систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____
(дата)

Зав. кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Коновалову Дмитрию Яковлевичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Генерация сообщений об ошибке ICMP»

ФГБОУ ВО «ВГТУ», ВГТУ
по заданию какой организации выполняется работа

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные –

4. Краткое содержание выпускной квалификационной работы

Раздел 1. Анализ баз данных киберугроз и инструментов риск-оценки
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Раздел 2. Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP»

Раздел 3. Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP»

Раздел 4. Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP»

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам)

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 – 22.05.25
2	Анализ баз данных киберугроз и инструментов риск-оценки	22.03.25 – 22.05.25
3	Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP»	23.05.25 – 31.05.25
4	Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP»	01.06.25 – 12.06.25
5	Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP»	13.06.25 – 24.06.25
6	Заключение	25.06.25 – 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося К-ОН

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение
высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ

выпускной квалификационной работы

Обучающегося Коновалова Дмитрия Яковлевича

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Генерация сообщений об ошибке ICMP»

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследование решает проблему отсутствия работ, связанных с оценкой и регулированием рисков успешности кибератак класса «Генерация сообщений об ошибке ICMP» для автоматизированных информационных систем.

Задачи, решаемые в ВКР:

− организация, сбор открытых интернет-источников и суммаризация данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

− установление соответствия между кибератаками класса «Генерация сообщений об ошибке ICMP» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

− оценка рисков нарушения информационной безопасности посредством кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости в автоматизированных информационных системах;

− формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости в автоматизированных информационных системах.

Структура ВКР

Введение – 5 страниц;

Глава 1. Анализ баз данных киберугроз и инструментов риск-оценки – 5 страниц;

Глава 2. Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP» – 20 страниц;

Глава 3. Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP» – 26 страниц;

Глава 4. Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP» – 4 страницы;

Заключение – 2 страницы;

Список литературы – 4 страницы;

Приложение А – 9 страниц;

Приложение Б – 7 страниц.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Анализ баз данных киберугроз и инструментов риск-оценки.

Проанализированы существующие базы данных киберугроз и инструменты риск-оценки;

Раздел 2. Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP».

Созданы таблицы соответствия шаблонов-уязвимостей и относящихся к ним тактик с техниками;

Раздел 3. Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP».

Проведена оценка риска единичных атак, а также созданы и разобраны возможные сценарии атак, включая экстремальные;

Раздел 4. Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP».

Разработаны организационные регламенты для устранения уязвимостей и понижения значения риска.

Автор ВКР_____ Коновалов Дмитрий Яковлевич

(подпись)

СОДЕРЖАНИЕ

Ввведение 7

1 Анализ баз данных киберугроз и инструментов риск-оценки 12

1.1 Анализ баз данных CAPEC, MITRE ATT&CK, БДУ ФСТЭК России и NVD.. 12

1.2 Исследование риск-калькуляторов CVSS, EPSS и OWASP 14

2 Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP» 17

2.1 Установление соответствий шаблонов CAPEC и эксплуатируемых уязвимостей..... 17

2.2 Разложение шаблонов CAPEC на техники MITRE ATT&CK..... 26

3 Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP» 37

3.1 Оценка критичности эксплуатируемых уязвимостей..... 37

3.2 Оценка рисков успешной реализации единичных вторжений и нахождение экстремальных сценариев атак для шаблонов CAPEC 48

4 Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP» 63

Заключение..... 67

Список литературы..... 69

Приложение А..... 73

Приложение Б 82

ВВЕДЕНИЕ

В связи с увеличением цифровизации, а также усиленной интеграцией автоматизированных информационных систем (АИС) в критически важные процессы, резко возрастает необходимость контролировать киберугрозы [1-8], способные нарушить конфиденциальность, целостность или доступность информации [8]. По данным аналитического отчёта Positive Technologies за 4 квартал 2024 года, среди всех зафиксированных успешных киберинцидентов на организации, распределение целей злоумышленников выглядит так:

– 53% – утечки конфиденциальной информации;

– 32% – нарушение основной деятельности;

– 6% – прямые финансовые потери;

– 6% – на ущерб интересам государства;

– 4% – использование ресурсов организации или частных лиц для проведения атак;

– 5% – другое;

– 13% – неизвестно [9].

Таким образом, больше половины успешных атак сопровождаются утечкой конфиденциальной информации. Это особенно критично в контексте атак класса «Генерация сообщений об ошибке ICMP», поскольку злоумышленники способны организовывать скрытые каналы для передачи информации, маскируя утечку под легитимные диагностические сообщения о работоспособности сети. В результате традиционные средства фильтрации ICMP трафика (блокировка нестандартного потока данных или ограничение пропускной способности) без полноценной оценки рисков и выстроенных регламентов часто оказываются недостаточными для предотвращения масштабных утечек информации. Поэтому в рамках данного исследования будет уделено особое внимание: сбору множеств уязвимостей, используя открытые базы данных [10-20], их оценке с помощью риск-калькуляторов [21-29] и последующему расчёту рисков успешности реализации атак [30-34], а также разработке организационных мер [35-40], применение которых сведёт уязвимости к минимуму и позволит системно управлять рисками.

Целеполагание настоящего исследования предполагает, что:

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Генерация сообщений об ошибке ICMP».

Предметом исследования является процесс обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Генерация сообщений об ошибке ICMP», включающий анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Генерация сообщений об ошибке ICMP».

Исследование аналогов показало наличие ряда **противоречий** между:

− необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака – уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Генерация сообщений об ошибке ICMP»;

− потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

− существующей методологией вероятностной оценки опасности кибератак класса «Генерация сообщений об ошибке ICMP» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

− несовершенством процедур регламентации противодействия кибератакам класса «Генерация сообщений об ошибке ICMP» и необходимостью осуществлять

такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

− организация, сбор открытых интернет-источников и суммаризация данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

− установление соответствия между кибератаками класса «Генерация сообщений об ошибке ICMP» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

− оценка рисков нарушения информационной безопасности посредством кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости в автоматизированных информационных системах;

− формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

− структурированная база данных кибератак класса «Генерация сообщений об ошибке ICMP» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

− векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

− методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Генерация сообщений об ошибке ICMP», с учётом специфики используемых злоумышленником сценариев;

− комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

− в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Генерация сообщений об ошибке ICMP», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

− впервые для класса кибератак «Генерация сообщений об ошибке ICMP» была предложена обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

− в отличие от аналогов, предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Генерация сообщений об ошибке ICMP», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

− для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Генерация сообщений об ошибке ICMP».

Практическая ценность полученных результатов видится в том, что:

− созданная база данных метрик кибератак класса «Генерация сообщений об ошибке ICMP» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

− сформированное множество сценариев и их риск-анализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Генерация сообщений об ошибке ICMP»;

− предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Генерация сообщений об ошибке ICMP», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

− предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Генерация сообщений об ошибке ICMP» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

− разработанные сценарии атак класса «Генерация сообщений об ошибке ICMP» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

− представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Генерация сообщений об ошибке ICMP» могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

− в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Анализ баз данных киберугроз и инструментов риск-оценки

1.1 Анализ баз данных CAPEC, MITRE ATT&CK, БДУ ФСТЭК России и NVD

Для качественной оценки и последующего регулирования рисков успешности атак на АИС по классу «Генерация сообщений об ошибке ICMP» необходимо опираться на достоверные источники знаний.

Перечень и классификация распространённых схем атак (CAPEC) представляет собой справочник распространённых шаблонов атак, что могут использоваться злоумышленниками для эксплуатации уязвимостей в программных системах. CAPEC даёт единый формат и структуру для описания приёмов и сценариев атак, что сильно упрощает обмен информацией специалистам безопасности друг с другом. При этом позволяет аналитикам и разработчикам заранее предвидеть возможные векторы атак и прорабатывать защитные меры. База данных CAPEC напрямую связана с другими базами организации MITRE. Таким образом, происходит интеграция с общим перечнем недостатков (CWE) и базой данных общеизвестных уязвимостей информационной безопасности (CVE), обеспечивая сквозную связь от слабости в коде до конкретного шаблона [10-20].

На данный момент последняя версия CAPEC (3.9) включает в себя 559 шаблонов атак. В записях CAPEC можно найти раздел «Связанные шаблоны ATT&CK», где стандартизованные шаблоны указывают на соответствующие техники из нашей следующей базы данных.

MITRE тактики, методы и общеизвестные знания о злоумышленниках (ATT&CK) – это открытая, постоянно обновляемая база знаний о поведении реальных злоумышленников на всех этапах атаки. В отличие от CAPEC, где описываются шаблоны приёмов атак, ATT&CK систематизирует наблюдаемые цели злоумышленника, именуемые тактиками и техниками (возможные способы для достижения поставленных целей) в виде матрицы [11].

В полной матрице на данный момент включено 211 техник и 468 подтехник. Переведённая на русский язык матрица представлена на ресурсе Positive Technologies [12].

Структура MITRE ATT&CK:

Тактики – цель на каждом этапе. В матрице всего их 14: разведка, подготовка ресурсов, первоначальный доступ, выполнение, закрепление, повышение привилегий, предотвращение обнаружения, получение учётных данных, обнаружение, перемещение внутри периметра, сбор данных, организация управления, эксфильтрация данных, деструктивное воздействие. Каждая техника может относиться к нескольким тактикам, а подтехники уточняют их [13-15].

Базы данных CAPEC и ATT&CK имеют общую цель в организации знаний об атаках, но делают это с разных, дополняющих друг друга, сторон. В то же время, банк данных угроз безопасности информации Федеральной службы по техническому и экспортному контролю России (БДУ ФСТЭК России) и Национальная база уязвимостей США (NVD) фокусируются на систематизации и оценке конкретных уязвимостей и угроз. БДУ ФСТЭК России формирует перечень возможных угроз и слабых мест, актуальных для информационной инфраструктуры Российской Федерации. NVD же выполняет функцию сбора и систематизации записей CVE, включая оценку критичности по шкале общей системы оценки уязвимостей (CVSS), для организации глобального управления рисками.

БДУ ФСТЭК России – это централизованный ресурс для описания и классификации угроз и уязвимостей, поддерживаемый Федеральной службой по техническому и экспортному контролю России [16]. На сегодняшний день в банке описано 227 угроз и более 70000 уязвимостей, включая как публично известные CVE, так и уязвимости, характерные инфраструктуре России [17-18].

NVD – официальная база данных уязвимостей «Национального института стандартов и технологий США» (NIST). Все CVE, назначаемые MITRE и уполномоченными организациями, автоматически попадают в NVD после приёма и прохождения проверки [19].

Использование БДУ ФСТЭК России и NVD вместе, позволит организациям в России гарантировать максимальное покрытие известных угроз и уязвимостей, что поможет оперативно реагировать на появляющиеся проблемы. Такой подход обеспечит комплексную защиту АИС на каждом шаге реализации атаки злоумышленника.

1.2 Исследование риск-калькуляторов CVSS, EPSS и OWASP

После анализа баз знаний и их формы представления данных, перейдём от классификации уязвимостей к количественной и вероятностной оценке их рисков. Общая система оценки уязвимостей (CVSS) – это стандарт, который используется для количественной оценки уязвимости. Хотя многие используют только базовую оценку CVSS для определения серьезности, также существуют временные и экологические оценки, которые учитывают доступность мер по смягчению. На данный момент имеется несколько версий стандарта, а именно CVSS v2, CVSS v3.1, CVSS v4.0. В последней версии была введена новая группа метрик и обновлена методология расчёта для более точного отражения контекста [21-23].

Вектор CVSS на примере версии 3.1 выглядит следующим образом: CVSS:3.1/AV:P/AC:L/PR:N/UI:R/S:C/C:L/I:N/A:N. В таблице 1 разберём процесс его создания.

Таблица 1 – Описание метрик стандарта CVSS:3.1

Аббревиатура	Полное название	Описание	Варианты значений
CVSS:3.1	Общая система оценки уязвимостей	Версия спецификации	–
AV	Вектор атаки	Место, откуда злоумышленник может инициировать атаку.	N – по сети; A – в пределах смежной сети; L – локально на хосте; P – через физический доступ.
AC	Сложность атаки	Сложность осуществления атаки при заданных обстоятельствах.	L – низкая сложность; H – высокая сложность.
PR	Требуемые привилегии	Требуемые злоумышленнику привилегии для начала атаки.	N – не требуется; L – низкий; H – высокий.
UI	Участие пользователя	Необходимость участия пользователя для успешной эксплуатации.	N – не требуется; R – требуется.

Продолжение таблицы 1

Аббревиатура	Полное название	Описание	Варианты значений
S	Влияние на другие компоненты системы	Распространяется ли влияние уязвимости за пределы первоначально затронутого компонента.	U – не оказывает; C – оказывает.
C	Влияние на конфиденциальность	Влияние на конфиденциальность (доступ к данным).	N – нет; L – частичное; H – полная потеря.
I	Влияние на целостность	Влияние на целостность данных.	N– нет; L – частичное; H – полная потеря.
A	Влияние на доступность	Влияние на доступность ресурса/системы.	N– нет; L – частичное; H – полная потеря.

Система оценки прогнозов эксплойтов (EPSS) – это открытый метод расчёта вероятности эксплуатации уязвимости в реальной среде. Его цель – дополнить существующие оценки серьёзности уязвимостей. В отличие от CVSS, что отражает статистическое значение критичности, EPSS показывает динамический риск реальной эксплуатации [24]. Этот метод предоставляет API, благодаря которому кто угодно может оперативно выгрузить данные интересующих уязвимостей. Процесс расчёта значения EPSS начинается с нормализации перечисленных метрик, далее применяется модель, обученная на данных об эксплуатации подобных уязвимостей, после чего система возвращает вероятность в пределах [0, 1], что интерпретируется как шанс на эксплуатацию данной уязвимости в течение следующих 30 дней [24].

Открытый проект безопасности веб-приложений (OWASP) – это независимая некоммерческая организация, цель которой – улучшить безопасность программного обеспечения путём предоставления бесплатных знаний, инструментов и методик для разработчиков, тестировщиков и менеджеров программного обеспечения [25].

Значение риска в данном проекте определяется вероятностью уязвимости и совершаемым ей воздействием. На вход вероятностной части аналитики получают общие сведения о злоумышленнике, такие как уровень навыков, мотив, возможности и размер группы (если больше одного), а также факторы уязвимости, в

числе которых лёгкость обнаружения, простота эксплуатации, осведомлённость и уровень обнаружения вторжений в системе [25].

Воздействие разделяют на факторы технического и делового влияния. В первом случае это потеря конфиденциальности, целостности, доступности и ответственности (можно ли отследить действия, совершаемые злоумышленником). В случае с бизнесом имеет место денежный и репутационный ущерб. В эту же категорию относят несогласие сотрудников и нарушение приватности в случае использования уязвимости. Все критерии получают экспертную оценку в пределах от 1 до 9 и после, по среднему значению внутри фактора, даётся словестное значение степени риска. Пересечение вероятности и тяжести и будет являться нашей оценкой [25].

В плане защиты АИС, комбинированное использование перечисленных риск-калькуляторов позволит эксперту по информационной безопасности выстроить правильный подход к защите, в том числе и от атак класса «Генерация сообщений об ошибке ICMP».

2 Разбор модели кибератак класса «Генерация сообщений об ошибке ICMP»

2.1 Установление соответствий шаблонов CAPEC и эксплуатируемых уязвимостей

Для начала разбора модели определим, какие шаблоны атак подходят под описание класса «Генерация сообщений об ошибке ICMP». Каждый из них должен уникально использовать создание, либо же анализ ICMP-сообщений. По этому критерию были выбраны шаблоны с CAPEC-329 по CAPEC-332. Они имеют общий родительский шаблон – CAPEC-312, что описывает технику активного определения операционной системы с помощью вызова сообщений. Цель состоит в сборе уникальных отпечатков поведения. К этим ответным сообщениям относятся и ICMP-ошибки [10]. Представим зависимости в классе в виде иерархического дерева на рисунке 1:

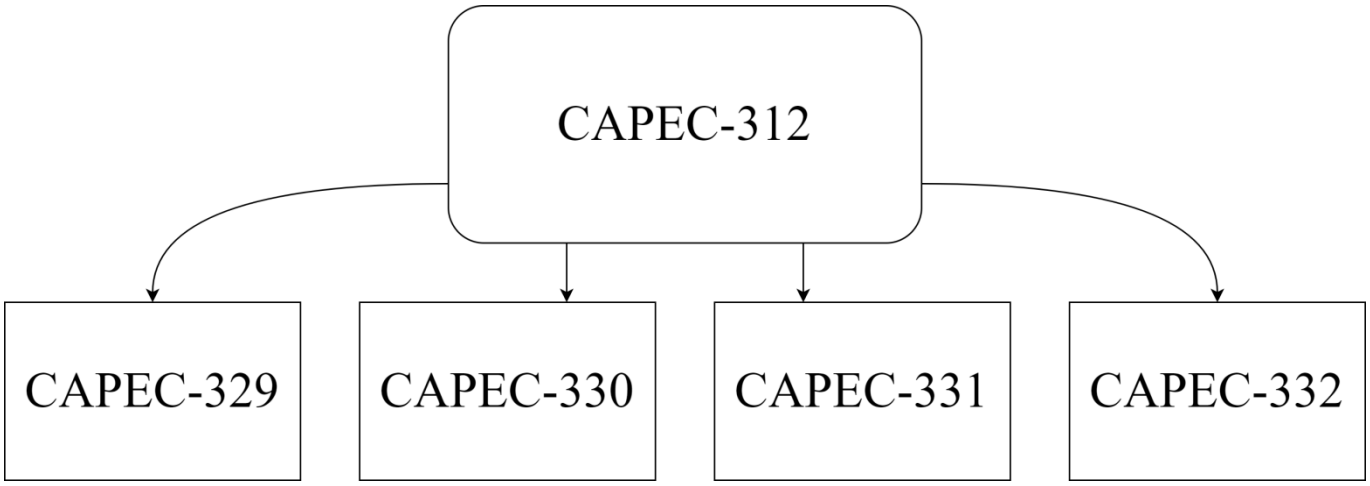


Рисунок 1 – Граф связи шаблонов CAPEC с родительским

Шаблон CAPEC-329 разбирает атаку, в которой злоумышленник анализирует ответные ошибки на объём данных, измеряя размер полученных сведений и сопоставляя их со своей базой. Это позволяет понять, какую операционную систему имеет жертва. Представим в виде паспорта [39] в таблице 2:

Таблица 2 – Паспорт шаблона атаки CAPEC-329

Идентификатор системы CAPEC	CAPEC-329 Исследование цитирования ICMP-сообщения об ошибке	
Описание шаблона атаки	Противник генерирует у цели ICMP-сообщение об ошибке (порт недоступен, пункт назначения недоступен, перенаправление, блокировка источника, превышение времени, проблема с параметрами) от цели, а затем анализирует объем данных, возвращенных или «зацитированных» из исходного запроса, который сгенерировал сообщение об ошибке ICMP.	
Тип атаки	Активное определение операционной системы	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: Раскрытие конфиденциальной информации неавторизованному лицу	Не рекомендован для использования в реальных уязвимостях

Шаблон атаки CAPEC-329: исследование цитирования ICMP-сообщения об ошибке, напрямую связан только с ошибкой CWE-200 – раскрытие конфиденциальной информации неавторизованному лицу. С помощью ресурса БДУ ФСТЭК России и NVD NIST [16, 19]: найдём связанные с данным шаблоном, через тип ошибки, уязвимости. Представим данную работу в таблице 3.

Таблица 3 – Соотношение CAPEC-329 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-329	ICMP Ошибка сообщения исследование цитирования	CWE-200	CVE-2025-21214
			CVE-2019-1318
			CVE-2024-42434
			CVE-2023-32016
			CVE-2023-0597
			CVE-2023-36908
			CVE-2023-24838
			CVE-2023-24901
			CVE-2022-34352
			CVE-2020-8832
			CVE-2024-26160
			CVE-2025-21308
			CVE-2023-29287
			CVE-2024-21340
			CVE-2020-3347

Продолжение таблицы 3

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
			CVE-2019-1048
			CVE-2024-38030
			CVE-2020-3520
			CVE-2025-24071
			CVE-2025-21242
			CVE-2025-27736
			CVE-2023-32041
			CVE-2023-35325
			CVE-2023-36889
			CVE-2024-30096
			CVE-2024-39823
			CVE-2021-39200
			CVE-2021-40690
			CVE-2021-39855
			CVE-2021-39856
			CVE-2021-39857
			CVE-2021-36192
			CVE-2021-34774
			CVE-2021-43536
			CVE-2021-45095

Пример паспорта данных уязвимостей представим в таблице 4. Паспорта некоторых уязвимостей для каждого из шаблонов указаны в приложении А.

Таблица 4 – Паспорт уязвимости CVE-2019-1318

Идентификатор уязвимости и его описание	CVE-2019-1318 Уязвимость реализации протокола TLS (Transport Layer Security) операционных систем Windows связана с недостатками фиксации сеанса. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации путем подключения к одноранговому узлу.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

Продолжение таблицы 4

Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,3)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Шаблон CAPEC-330 в отличие от предыдущего, фокусируется не только на объёме цитаты, но и на содержимом данного ответа и целостности данных. Это позволяет извлекать IP-заголовок из ошибки. Представим паспорт в таблице 5:

Таблица 5 – Паспорт шаблона атаки CAPEC-330

Идентификатор системы CAPEC	CAPEC-330 Проверка целостности цитируемых данных ICMP-сообщения об ошибке.	
Описание шаблона атаки	Злоумышленник использует технику для генерации сообщения об ошибке ICMP (порт недоступен, пункт назначения недоступен, перенаправление, блокировка источника, превышение времени, проблема с параметрами) от цели, а затем анализирует целостность данных, возвращенных или «зацитированных» из исходного запроса, который сгенерировал сообщение об ошибке.	
Тип атаки	Активное определение операционной системы	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200: Раскрытие конфиденциальной информации неавторизованному лицу	Не рекомендован для использования в реальных уязвимостях

Шаблон атаки CAPEC-330: проверка целостности цитируемых данных ICMP-сообщения об ошибке, как и предыдущий шаблон, связан только с ошибкой CWE-200 – раскрытие конфиденциальной информации неавторизованному лицу. Укажем

связанные с данным шаблоном через выбранный тип ошибки уязвимости и представим их в таблице 6.

Таблица 6 – Соотношение CAPEC-330 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-330	Сообщение об ошибке ICMP, отражающее проверку целостности	CWE-200	CVE-2024-39822
			CVE-2021-44702
			CVE-2021-44739
			CVE-2022-0281
			CVE-2022-21712
			CVE-2021-22785
			CVE-2021-45420
			CVE-2024-4008
			CVE-2021-3677
			CVE-2022-0813
			CVE-2022-27241
			CVE-2021-28544
			CVE-2022-25166
			CVE-2022-20734
			CVE-2022-20664
			CVE-2024-50338
			CVE-2022-33742
			CVE-2020-4159
			CVE-2022-35169
			CVE-2022-34659
			CVE-2021-3800
			CVE-2022-31143
			CVE-2022-31746
			CVE-2023-22875
			CVE-2022-43959
			CVE-2021-22786
			CVE-2024-47080
			CVE-2023-27478
			CVE-2023-0027
			CVE-2024-20457
			CVE-2023-0836
			CVE-2023-1258
			CVE-2023-29517
			CVE-2022-34352

Полный паспорт одной уязвимости из таблицы 6 представлен в таблице 7.

Таблица 7 – Паспорт уязвимости CVE-2024-39822

Идентификатор уязвимости	CVE-2024-39822 Уязвимость программного обеспечения для проведения видеоконференций Zoom Workplace, SDK, клиентах Rooms и контроллерах Rooms связана с недостаточной защитой служебных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Шаблон CAPEC-331 извлекает из поля IP-заголовка полную длину для сравнения сигнатур и определения операционной системы. Представим паспорт в таблице 8:

Таблица 8 – Паспорт шаблона атаки CAPEC-331

Идентификатор системы CAPEC	CAPEC-331 ICMP исследование общей длины поля IP.
Описание шаблона атаки	Злоумышленник отправляет пакет UDP на закрытый порт на целевой машине, чтобы запросить значение поля общей длины заголовка IP в возвращаемом сообщении об ошибке «порт недоступен». Такой тип поведения полезен для создания базы сигнатур ответов операционной системы, особенно когда сообщения об ошибках содержат другие типы информации, полезные для идентификации конкретных

Продолжение таблицы 8

	ответов операционной системы.	
Тип атаки	Активное определение операционной системы	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-204: Наблюдаемое расхождение в ответах	Этот идентификатор CWE может быть использован для сопоставления с реальными уязвимостями

Шаблон атаки CAPEC-331: ICMP исследование общей длины поля IP, связан с ошибкой CWE-204 – наблюдаемое расхождение в ответах. Выберем относящиеся к данному шаблону через соответствующий тип ошибки уязвимости и представим их в таблице 9.

Таблица 9 – Соотношение CAPEC-331 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-331	ICMP исследование общей длины поля IP	CWE-204	CVE-2023-3336
			CVE-2024-39912
			CVE-2024-36996
			CVE-2022-31248
			CVE-2022-22520
			CVE-2022-41697
			CVE-2023-32346
			CVE-2023-39343
			CVE-2023-40179
			CVE-2024-2482
			CVE-2023-33859
			CVE-2024-13028
			CVE-2024-13198
			CVE-2025-23214
			CVE-2022-20633

Полный паспорт одной из уязвимостей шаблона CAPEC-331 представлен в таблице 10:

Таблица 10 – Паспорт уязвимости CVE-2024-39912

Идентификатор уязвимости	CVE-2024-39912 Уязвимость библиотеки аутентификации в веб-приложениях webauthn-lib. Связана с несоответствием ответов на входящие запросы в методе ProfileBasedRequestOptionsBuilder. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Шаблон CAPEC-332 сравнивает возвращённое значение с отправленным в UDP-пакете полем ID. Анализ ответа позволяет злоумышленнику выявить алгоритм генерации ID в атакуемой системе. Представим паспорт в таблице 11:

Таблица 11 – Паспорт шаблона атаки CAPEC-332

Идентификатор системы CAPEC	CAPEC-332 Проверка поля «ID» IP-заголовка в ICMP сообщении об ошибке
Описание шаблона атаки	Злоумышленник отправляет UDP-дейтаграмму с присвоенным значением его полю интернет-идентификации (ID) на закрытый порт цели, чтобы наблюдать, как этот бит отражается обратно в сообщении об ошибке ICMP. Это позволяет злоумышленнику создать отпечаток поведения ОС.

Продолжение таблицы 11

Тип атаки	Активное определение операционной системы	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-204: Наблюдаемое расхождение в ответах	Этот идентификатор CWE может быть использован для сопоставления с реальными уязвимостями

Шаблон атаки CAPEC-332: проверка поля «ID» IP-заголовка в ICMP сообщении об ошибке, как и предыдущий шаблон, связан исключительно с ошибкой CWE-204 – наблюдаемое расхождение в ответах. Выберем относящиеся к данному шаблону через тип ошибки уязвимости и представим их в таблице 12.

Таблица 12 – Соотношение CAPEC-332 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-332	Проверка сообщения об ошибке поля «ID» IP-протокола ICMP	CWE-204	CVE-2025-30280
			CVE-2023-49069
			CVE-2024-42343
			CVE-2024-35114
			CVE-2023-47159
			CVE-2023-37413
			CVE-2025-23193
			CVE-2025-1101
			CVE-2025-24023
			CVE-2025-2910
			CVE-2025-31124
			CVE-2024-56476
			CVE-2025-30150
			CVE-2025-46736
			CVE-2021-37751

Полный паспорт одной из уязвимостей CAPEC-332 представлен в таблице 13:

Таблица 13 – Паспорт уязвимости CVE-2025-30280

Идентификатор уязвимости	CVE-2025-30280 Уязвимость Mendix Runtime. Во время данной уязвимости возникает несоответствие ответов на входящие запросы. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

2.2 Разложение шаблонов CAPEC на техники MITRE ATT&CK

Для более глубокого анализа угроз, разложим шаблоны CAPEC на отдельные тактики и техники из базы данных MITRE ATT&CK [11]. Сопоставим проанализированные уязвимости с подходящими классификациями из матрицы. Таким образом, каждая уязвимость системы будет привязана к конкретному шагу производимой атаки – от разведки и первоначального доступа, до сбора данных и деструктивного воздействия. Это позволит получить чёткую картину последовательности действий злоумышленника для создания защитных мер.

В CAPEC-329 ключевым способом начала атаки является эксплуатация уязвимостей в публично-доступных компонентах и клиентском программном обеспечении. По методологии MITRE, это является техникой (T1190) внутри тактики «первоначальный доступ».

Недостатки в общедоступном приложении:

1) CVE-2019-1318 – уязвимость в сетевом сервисе, что позволяет удалённо выполнить произвольный код без аутентификации;

2) CVE-2024-42434 – дыра в веб-портале, через которую злоумышленник получает доступ к командной строке операционной системы.

Дальнейшая стадия выполнения кода показана на примере запуска собственных команд через уязвимости в клиентских приложениях (T1203) и использовании командных интерпретаторов (T1059), что является тактикой выполнения.

Эксплуатация уязвимостей в клиентском ПО:

1) CVE-2023-32016 – баг в офисном приложении, позволяющий запуск скриптов при открытии файла;

2) CVE-2023-0597 – уязвимость в мультимедийном плагине для браузера.

Интерпретаторы командной строки и сценариев:

1) CVE-2023-36908 – обход ограничений PowerShell, дающий возможность выполнить встроенные команды;

2) CVE-2023-24838 – ошибка в интерпретаторе Python, позволяющая загрузить и исполнить вредоносный модуль.

Для повышения привилегий используются как «внедрение кода в процессы» (T1055), так и «прямая эксплуатация локальных уязвимостей ядра» (T1068).

Внедрение кода в процессы:

1) CVE-2023-24901 – позволяет получать информацию о внутренних структурах памяти и сервисах через созданные вредоносные запросы, что упрощает внедрение библиотек злоумышленника в процессы системы;

2) CVE-2022-34352 – из-за отсутствия надёжной изоляции между доменами, возможен доступ к объектам другого домена. Это раскрытие контекста позволяет вшивать вредоносный код в пространстве происходящих процессов;

3) CVE-2020-8832 – из-за неполного исправления ошибки в ядре Linux, позволяет точечно внедрять собственный код в процессы на уровне ядра или драйверов.

Эксплуатация уязвимостей для повышения привилегий:

1) CVE-2024-26160 – благодаря переполнению буфера, позволяет локальному злоумышленнику читать лишние области памяти драйвера, что является отправной точкой для получения системных привилегий;

2) CVE-2025-21308 – позволяет загрузить и выполнить вредоносный файл темы оформления Windows с повышенными правами, обойдя штатные проверки и достигнув эскалации до уровня администратора;

3) CVE-2023-29287 – позволяет расширить права в системе через раскрытие внутреннего API.

После получения нужных прав злоумышленник собирает информацию об аккаунтах через тактику «обнаружение». Изучение учётных записей (T1087):

1) CVE-2024-21340 – напрямую соответствует технике, поскольку злоумышленник получает сведения о доступных учётных записях и уровне их привилегий;

2) CVE-2020-3347 – баг, при котором запрос сведений о пользователе возвращает не только профиль запрашиваемого аккаунта, но и полную иерархию групп и членств.

В финальной фазе производится «деструктивное воздействие» через технику «уничтожение данных» (T1485):

1) CVE-2019-1048 – позволяет удалённо отправить специально сформированный запрос, из-за чего происходило безвозвратное удаление важных файлов в службе печати;

2) CVE-2024-38030 – при подаче некорректного параметра весь каталог с резервными копиями очищался без дополнительного подтверждения;

3) CVE-2020-3520 – позволяет через SQL-инъекцию выполнить команду DROP TABLE для любых таблиц.

Объединим все полученные данные в виде таблицы 14:

Таблица 14 – Соотнесение техник и тактик с уязвимостями для CAPEC-329

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 – Недостатки в общедоступном приложении	CVE-2019-1318
		CVE-2024-42434
Выполнение	T1203 – Эксплуатация уязвимостей в клиентском ПО	CVE-2023-32016
		CVE-2023-0597
	T1059 – Интерпретаторы командной строки и сценариев	CVE-2023-36908
		CVE-2023-24838
Повышение привилегий	T1055 – Внедрение кода в процессы	CVE-2023-24901
		CVE-2022-34352
		CVE-2020-8832
	T1068 – Эксплуатация уязвимостей для повышения привилегий	CVE-2024-26160
		CVE-2025-21308
		CVE-2023-29287
Обнаружение	T1087 – Изучение учётных записей	CVE-2024-21340
		CVE-2020-3347
Деструктивное воздействие	T1485 – Уничтожение данных	CVE-2019-1048
		CVE-2024-38030
		CVE-2020-3520

В шаблоне CAPEC-330 возможна многоступенчатая атака, в которой злоумышленник начинает с активного сканирования и постепенно движется к сбору данных. Сначала на этапе активного сканирования применяется техника (T1595):

1) CVE-2021-22786 – позволяет через специальный HTTP-запрос собрать информацию о конфигурации и запущенных модулях;

2) CVE-2023-0027 – баг в сетевом оборудовании, раскрывающий версии прошивки и доступные сервисы по результатам сканирования.

Далее для первоначального доступа он эксплуатирует дыры в общедоступных приложениях (T1190):

1) CVE-2022-0281 – позволяет запустить произвольный код;

2) CVE-2022-0813 – обход аутентификации через подделку запроса;

3) CVE-2022-27241 – SQL-инъекция в публичном портале;

4) CVE-2022-20734 – уязвимость в модуле загрузки файлов, ведущая к запуску shell-команд.

После закрепления, для повышения привилегий используется техника (T1068):

1) CVE-2021-3800 – баг в драйвере, позволяющий любому процессу повысить привилегии до SYSTEM;

2) CVE-2022-25166 – уязвимость в ядре, через которую локальный пользователь получает root-доступ.

Для тактики «получение учётных данных» используются такие техники как «учётные данные из хранилищ паролей» (T1555):

1) CVE-2021-44702 – уязвимость в менеджере паролей, дающая обход шифрования;

2) CVE-2024-47080 – позволяет экспортировать все сохранённые логины;

3) CVE-2022-35169 – уязвимость, раскрывающая токены доступа.

А также «незащищенные учётные данные» (T1552):

1) CVE-2024-50338 – сервис логирования сохраняет внутренние токены в открытом тексте;

2) CVE-2022-43959 – ошибка, при которой секретные ключи попадают в логи;

3) CVE-2024-20457 – уязвимость в скрипте автоматизации, где пароль к базе жёстко прописан в коде.

Для обнаружения, атакующий перебирает файлы и каталоги (T1083) — это иллюстрирует CVE-2022-34659. Данная уязвимость в утилите управления файлами позволяет читать каталоговые списки любых директорий, включая системные.

На этапе «сбор данных» извлекает локальные данные техникой (T1005):

1) CVE-2022-33742 – баг в драйвере файловой системы, раскрывающий содержимое скрытых папок;

2) CVE-2024-39822 – уязвимость в модуле шифрования дисков, позволяющая получить незашифрованные данные;

3) CVE-2021-3677 – уязвимость в службе резервного копирования, через которую можно было выгрузить копию базы.

Данные из информационных репозиториев (T1213):

1) CVE-2020-4159 – SQL-инъекция для скачивания отчёты и сырые данные;

2) CVE-2022-34352 – уязвимость в модуле репликации СУБД, через которую можно получить дампы всех таблиц.

Представим данную информацию в виде таблицы 15:

Таблица 15 – Соотнесение техник и тактик с уязвимостями для CAPEC-330

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Активное сканирование	T1595 – Разведка	CVE-2021-22786
		CVE-2023-0027
Первоначальный доступ	T1190 – Недостатки в общедоступном приложении	CVE-2022-0281
		CVE-2022-0813
		CVE-2022-27241
		CVE-2022-20734
Повышение привилегий	T1068 – Эксплуатация уязвимостей для повышения привилегий	CVE-2021-3800
		CVE-2022-25166
Получение учётных данных	T1555 – Учётные данные из хранилищ паролей	CVE-2021-44702
		CVE-2024-47080
		CVE-2022-35169
	T1552 – Незащищенные учётные данные	CVE-2024-50338
		CVE-2022-43959
		CVE-2024-20457
Обнаружение	T1083 – Изучение файлов и каталогов	CVE-2022-34659
Сбор данных	T1005 – Данные из локальной системы	CVE-2022-33742
		CVE-2024-39822
		CVE-2021-3677
	T1213 – Данные из информационных репозиториев	CVE-2020-4159
		CVE-2022-34352

В CAPEC-331 описывается сценарий, в котором злоумышленник начинает атаку с первоначального доступа через недостатки в общедоступном приложении (T1190):

1) CVE-2024-36996 – уязвимость в модуле аутентификации веб-портала, позволяющая выполнить произвольный запрос от имени администратора;

2) CVE-2022-31248 – баг в API управления контентом, через который можно загружать и исполнять вредоносные файлы.

Через существующие учётные записи (T1078):

1) CVE-2023-40179 – уязвимость в службе аутентификации, позволяющая обойти запрет входа для заблокированных пользователей, войдя под чужим логином;

2) CVE-2024-13198 – баг в модуле SSO, дающий возможность подменить токен авторизации другого пользователя.

Интерпретаторы командной строки и сценариев (T1059):

1) CVE-2023-003336 – уязвимость в движке скриптового языка, позволяющая выполнять внешние команды при обработке специально сформированного скрипта;

2) CVE-2024-39912 – баг в интерпретаторе Bash, обходящий ограничения Safe Mode и исполняющий произвольный код.

Для предотвращения обнаружения, уязвимости идут через ослабление защиты (T1562):

1) CVE-2024-2482 – уязвимость в службе ведения логов Windows, позволяющая удалить записи о своих действиях;

2) CVE-2023-39343 – баг в модуле защиты в реальном времени, дающий возможность на определённый срок отключить антивирус при загрузке DLL.

Получение учётных данных через метод перебора (T1110):

1) CVE-2022-22520 – уязвимость в веб-форме аутентификации, которая не ограничивает число попыток ввода пароля;

2) CVE-2022-41697 – баг в SSH, позволяющий проводить длительный перебор паролей без блокировки.

Перемещение внутри периметра – это фаза, в которой злоумышленник, получивший точку опоры в сети, использует доступные удалённые сервисы для

перехода с одной машины на другую. Это позволяет ему расширить контроль над сетью. В нашем случае, использует технику «службы удалённого доступа» (T1021):

1) CVE-2023-32346 – уязвимость в службе, позволяющая подключиться без проверки прав;

2) CVE-2025-23214 – баг в SSH-сервере, дающий неавторизованный доступ к командной строке.

Эксфильтрация данных происходит по каналу управления (T1041):

1) CVE-2023-33859 – уязвимость в библиотеке сетевого обмена, позволяющая перехватывать и перенаправлять внутренний трафик;

2) CVE-2024-13028 – баг в модуле SSL/TLS-клиента, дающий возможность вставлять скрытые пакеты данных в существующее соединение [11, 16].

Деструктивное воздействие идёт с применением шифрования данных (T1486). CVE-2022-20633 – уязвимость в службе управления дисками, через которую можно массово зашифровать разделы без возможности восстановления.

Соберём полученные данные в таблицу 16:

Таблица 16 – Соотнесение техник и тактик с уязвимостями для CAPEC-331

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 – Недостатки в общедоступном приложении	CVE-2024-36996
		CVE-2022-31248
	T1078 – Существующие учётные записи	CVE-2023-40179
		CVE-2024-13198
Выполнение	T1059 – Интерпретаторы командной строки и сценариев	CVE-2023-3336
		CVE-2024-39912
Предотвращение обнаружения	T1562 – Ослабление защиты	CVE-2024-2482
		CVE-2023-39343
Получение учётных данных	T1110 – Метод перебора	CVE-2022-22520
		CVE-2022-41697
Перемещение внутри периметра	T1021 – Службы удалённого доступа	CVE-2023-32346
		CVE-2025-23214

Продолжение таблицы 16

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Эксфильтрация данных	T1041 - Эксфильтрация по каналу управления	CVE-2023-33859
		CVE-2024-13028
Деструктивное воздействие	T1486 - Шифрование данных	CVE-2022-20633

Шаблон CAPEC-332 не имеет тактик, что не были рассмотрены нами выше. Активное сканирование (T1595) исходит из уязвимости CVE-2025-30280. Она появляется в сетевой службе и даёт возможность через специально сформированные сканы получить список запущенных приложений и номера их версий.

Техника существующих учётных записей (T1078) состоит в использовании заранее украденных или слабых учётных записей для входа в систему. В нашем случае это происходит из-за уязвимости CVE-2025-24023. Это баг в компоненте аутентификации, позволяющий обойти проверку пароля при предоставлении заранее известного значения.

Недостатки в общедоступном приложении (T1190):

1) CVE-2024-35114 – удалённое выполнение кода через неверную валидацию входных параметров в публичном веб-сервисе;

2) CVE-2023-37413 – обход проверки прав при загрузке файлов, приводящий к RCE;

3) CVE-2025-1101 – SQL-инъекция в REST-API, дающая полный доступ к базе данных.

Техника загрузки сторонних DLL-библиотек (T1574.002) эксплуатирует уязвимость CVE-2021-37751. Уязвимость в загрузчике модуля Windows, позволяющая подменить путь к DLL и запустить вредоносный код при старте приложения.

Отключение или перенастройка средств защиты (T1562.001) возможна через:

1) CVE-2023-49069 – баг в службе безопасности, который позволяет отключить компоненты защитного ПО;

2) CVE-2025-31124 – уязвимость в модуле логирования, позволяющая стереть или подменить записи о событиях.

Изучение локальной учётной записи (T1087.001):

1) CVE-2024-42343 – уязвимость в API управления пользователями, раскрывающая список всех локальных аккаунтов;

2) CVE-2025-46736 – баг в утилите администратора, позволяющий получить детали учётных записей без достаточных прав.

Эксфильтрация по каналу управления (T1041) представляет собой пересылку похищенных данных через уже установленный канал командно-контрольного сервера:

1) CVE-2025-2910 – уязвимость в библиотеке C2-клиента, позволяющая внедрить в трафик пакеты с конфиденциальными файлами;

2) CVE-2025-30150 – баг в протоколе обмена, дающий возможность скрытно перенаправлять данные из корпуса жертвы.

Точечный отказ в обслуживании (T1499) представляет собой избирательную атаку, нарушающую работу конкретного сервиса или приложения:

1) CVE-2023-47159 – уязвимость в сетевом драйвере, позволяющая через разовую посылку пакета вывести из строя сервис VPN;

2) CVE-2024-56476 – баг в HTTP-сервере, приводящий к краху процесса при специфичных запросах;

3) CVE-2025-23193 – уязвимость в службе управления памятью, провоцирующая точечный сбой по API-вызову.

Кратко представим полученные данные в виде таблицы 17:

Таблица 17 – Соотнесение техник и тактик с уязвимостями для CAPEC-332

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Разведка	T1595 – Активное сканирование	CVE-2025-30280
Первоначальный доступ	T1078 – Существующие учётные записи	CVE-2025-24023

Продолжение таблицы 17

Тактика	Техника	Уязвимости, эксплуатируемые соответствующей техникой
Первоначальный доступ	T1190 – Недостатки в общедоступном приложении	CVE-2024-35114
		CVE-2023-37413
		CVE-2025-1101
Закрепление	T1574.002 – Загрузка сторонних DLL-библиотек	CVE-2021-37751
Предотвращение обнаружения	T1562.001 – Отключение или перенастройка средств защиты	CVE-2023-49069
		CVE-2025-31124
Обнаружение	T1087.001 – Изучение локальной учётной записи	CVE-2024-42343
		CVE-2025-46736
Эксфильтрация данных	T1041 – Эксфильтрация по каналу управления	CVE-2025-2910
		CVE-2025-30150
Деструктивное воздействие	T1499 – Точечный отказ в обслуживании	CVE-2023-47159
		CVE-2024-56476
		CVE-2025-23193

3 Оценка рисков успешной реализации кибератак класса «Генерация сообщений об ошибке ICMP»

3.1 Оценка критичности эксплуатируемых уязвимостей

В данной главе будет дана комплексная оценка критичности уязвимостей, представленных ранее. Первым шагом на этом пути послужит сводная таблица, объединяющая результаты оценки уязвимостей по четырём ключевым метрикам – CVSS 3.x, CVSS 4.0, EPSS и OWASP [21-25]. Она позволит получить общее представление о серьёзности каждой из уязвимостей, согласно калькуляторам [26-29]. Оценки представим в таблицах 18-21:

Таблица 18 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC-329

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-21214	4,2	4,1	0,61	4,375
CVE-2019-1318	5,9	8,2	0,5285	6
CVE-2024-42434	4,9	6,9	0,92	5,25
CVE-2023-32016	5,5	6,8	0,55	4,25
CVE-2023-0597	5,5	6,8	0,16	6,125
CVE-2023-36908	6,5	7,1	0,506	5,125
CVE-2023-24838	9,8	9,3	0,1354	7,375
CVE-2023-24901	7,5	8,7	0,653	5,5
CVE-2022-34352	6,5	7,1	0,7	5,5
CVE-2020-8832	5,5	6,7	0,65	5
CVE-2024-26160	5,5	6,8	0,37592	3,875
CVE-2025-21308	6,5	7,2	0,803	5,25
CVE-2023-29287	5,3	6,9	0,263	4,125
CVE-2024-21340	4,6	5,1	0,44	3,375
CVE-2020-3347	5,5	6,8	0,71	7,25
CVE-2019-1048	6,5	6	0,437	3,75
CVE-2024-38030	6,5	7,1	0,7222	4,375
CVE-2020-3520	5,5	6,8	0,61	5,625
CVE-2025-24071	7,5	8,7	0,66783	4,875
CVE-2025-21242	5,9	8,2	0,96	5
CVE-2025-27736	5,5	6,8	0,44	4,5
CVE-2023-32041	5,5	6,8	0,776	4,75
CVE-2023-35325	7,5	8,7	0,863	6,5
CVE-2023-36889	5,5	6,8	0,402	4,875
CVE-2024-30096	5,5	6,8	0,581	5
CVE-2024-39823	6,5	7,4	0,7	6

Продолжение таблицы 18

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2021-39200	5,3	6	0,1771	6,25
CVE-2021-40690	7,5	8,7	0,335	6,125
CVE-2021-39855	6,5	6,9	0,2023	5,25
CVE-2021-39856	6,5	6,9	0,2023	5,625
CVE-2021-39857	4,3	5,1	0,53	7
CVE-2021-36192	5,2	4,8	0,54	6,625
CVE-2021-34774	4,9	6,9	0,51	7,375
CVE-2021-43536	6,5	6,9	0,373	4,875
CVE-2021-45095	5,5	6,8	0,11	5,625

Таблица 19 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC-330

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-39822	6,5	7,1	0,7	5,5
CVE-2021-44702	4,3	5,1	0,4723	7,25
CVE-2021-44739	4,3	5,1	0,45	5,125
CVE-2022-0281	7,5	8,7	0,74183	6,625
CVE-2022-21712	7,5	8,7	0,513	3,375
CVE-2021-22785	7,5	8,7	0,402	3
CVE-2021-45420	9,8	9,3	0,7872	6,625
CVE-2024-4008	9,6	7,3	0,79	5
CVE-2021-3677	6,5	7,1	0,563	4,125
CVE-2022-0813	5,3	6,9	0,48	3,375
CVE-2022-27241	7,5	8,7	0,537	3,5
CVE-2021-28544	4,3	5,3	0,414	4,75
CVE-2022-25166	5	5,1	0,4665	6,25
CVE-2022-20734	4,4	6,7	0,62	5,25
CVE-2022-20664	7,7	8,3	0,431	3,75
CVE-2024-50338	7,4	8,2	0,87	3,625
CVE-2022-33742	7,1	6,9	0,33	4
CVE-2020-4159	7,5	8,7	0,707	7,25
CVE-2022-35169	6	7	0,415	4
CVE-2022-34659	7,5	8,7	0,273	7,5
CVE-2021-3800	5,5	6,7	0,4	7
CVE-2022-31143	5,3	6,9	0,5	5,75
CVE-2022-31746	6,5	6,9	0,457	5,75
CVE-2023-22875	8,4	9,2	0,43	5,75
CVE-2022-43959	4,9	6,9	0,426	4,75
CVE-2021-22786	7,5	8,7	0,575	4,5
CVE-2024-47080	7	8,7	0,675	5,875
CVE-2023-27478	6,5	6,9	0,147	5,375
CVE-2023-0027	5,3	6,9	0,37	4,25
CVE-2024-20457	6,5	7,1	0,73	4,75

Продолжение таблицы 19

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2023-0836	7,5	8,7	0,4	6,75
CVE-2023-1258	5,3	6,9	0,7024	5,5
CVE-2023-29517	7,5	8,7	0,1391	3,625
CVE-2022-34352	6,5	7,1	0,64	7,25

Таблица 20 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC-331

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2023-3336	7,5	8,7	0,681	6,5
CVE-2024-39912	5,3	6,9	0,535	5,125
CVE-2024-36996	5,3	6,9	0,576	3,125
CVE-2022-31248	5,3	6,9	0,32	5,125
CVE-2022-22520	5,3	6,9	0,49	5,125
CVE-2022-41697	5,3	6,9	0,38	4,125
CVE-2023-32346	5,3	6,9	0,37	3,75
CVE-2023-39343	4,3	5,3	0,84	5,75
CVE-2023-40179	5,3	6,9	0,72	3,375
CVE-2024-2482	3,7	6,3	0,5	5,75
CVE-2023-33859	5,3	6,9	0,69	3,125
CVE-2024-13028	3,7	6,3	0,53	6
CVE-2024-13198	3,7	6,3	0,55	6,875
CVE-2025-23214	5,5	6,9	0,61	7,125
CVE-2022-20633	5	6,9	0,52	6,375

Таблица 21 – Оценка уязвимостей с помощью риск-калькуляторов для CAPEC-332

Идентификатор уязвимости	Оценка CVSS 3.x	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-30280	5,3	6,9	0,38	6,25
CVE-2023-49069	5,3	6,9	0,59	3,25
CVE-2024-42343	5,3	6,9	0,82	6,75
CVE-2024-35114	5,3	6,9	0,25	5
CVE-2023-47159	4,3	5,3	0,34	6,875
CVE-2023-37413	5,3	6,9	0,37	5,5
CVE-2025-23193	5,3	6,9	0,47	4,375
CVE-2025-1101	5,3	6,9	0,7	4,25
CVE-2025-24023	3,7	6,3	0,5	6,875
CVE-2025-2910	5	6,9	0,69	4,875
CVE-2025-31124	5,3	6,9	0,64	5,25
CVE-2024-56476	5,3	6,9	0,35	5,875
CVE-2025-30150	4	5,5	0,55	3,25
CVE-2025-46736	5,3	6,9	0,27	3,125
CVE-2021-37751	7,5	8,7	0,75	3,625

Важным моментом здесь является формализация исходных метрик, полученных с помощью используемых риск-калькуляторов. Поскольку каждый из них оперирует собственным диапазоном и набором факторов, необходимо привести все оценки к общей нормированной шкале. Это позволит без проблем сравнивать их значения и использовать в дальнейших расчётах. Найдём нормализованные оценки критичности уязвимостей по формуле (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \tag{1}$$

где S_{min}– минимальное и максимальное возможные значения шкалы S,

S_{max} – максимальное возможное значение шкалы S [30, 31].

Для имеющихся значений калькуляторов CVSS 3.x, CVSS 4.0 и OWASP имеем $S_{min} = 0,\ S_{max} = 10$. Значения EPSS имеют вероятностное представление и находятся в пределах $S_{min} = 0,\ S_{max} = 1$, это означает, что шкала уже нормализована [24]. Затем для каждой уязвимости проведём расчёт среднего значения нормализованных показателей. Формула (2) для его нахождения выглядит следующим образом [30, 31]:

$$\bar{S} = \frac{1}{4}\left(S_{norm,\,1} + S_{norm,\,2} + S_{norm,\,3} + S_{norm,\,4}\right), \tag{2}$$

где $S_{norm,i}$ – нормализованные оценки критичности соответствующих порядку представленных в таблице калькуляторов, посчитанные по формуле (1).

Для более гибкого учёта разброса оценок, введём дополнительные метрики. Стандартное отклонение нормализованных оценок найдём по формуле (3):

$$\sigma = \sqrt{\frac{1}{3}((S_{norm,1} - \bar{S})^2 + (S_{norm,2} - \bar{S})^2 + (S_{norm,3} - \bar{S})^2 + (S_{norm,4} - \bar{S})^2)}, \quad (3)$$

где делитель равен 3, так как при оценке дисперсии число степеней свободы считается равной: $m - 1$, m – число калькуляторов [30, 31].

Нормализованные оценки (1), среднее их значение (2), а также стандартное отклонение нормализованных оценок (3), на примере нескольких уязвимостей из таблицы 18, представим в таблице 22:

Таблица 22 – Нормализованные оценки, среднее значение и стандартное отклонение нормализованных оценок для уязвимостей

CVE	$S_{norm,1}$	$S_{norm,2}$	$S_{norm,3}$	$S_{norm,4}$	$\bar{S}$	σ
CVE-2025-21214	0,42	0,41	0,61	0,4375	0,469375	0,0944364
CVE-2019-1318	0,59	0,82	0,5285	0,6	0,634625	0,1275626
CVE-2024-42434	0,49	0,69	0,92	0,525	0,65625	0,1962726
CVE-2023-32016	0,55	0,68	0,55	0,425	0,55125	0,1041133
CVE-2023-0597	0,55	0,68	0,16	0,6125	0,500625	0,233206
CVE-2023-36908	0,65	0,71	0,506	0,5125	0,594625	0,101615

Значимость (вес) калькуляторов определяет, насколько вклад каждого отдельного риск-калькулятора в итоговую оценку критичности отличается от средней, и тем самым решает, какие оценки заслуживают большего внимания при агрегации [30, 31]. Найдем вес по формуле (4) и представим в таблице 23.

$$w_i = \frac{S_{norm,i}}{\sigma}. \quad (4)$$

Таблица 23 – Расчёт веса калькуляторов для уязвимостей

CVE	w_1	w_2	w_3	w_4
CVE-2025-21214	4,447439	4,341547	6,459375	4,632749
CVE-2019-1318	4,625178	6,428214	4,143062	4,703571
CVE-2024-42434	2,496528	3,515519	4,687359	2,674852
CVE-2023-32016	5,282705	6,531345	5,282705	4,082091
CVE-2023-0597	2,358433	2,915881	0,68609	2,626437
CVE-2023-36908	6,396708	6,987173	4,979591	5,043558

Чтобы сумма весов давала единицу, и мы могли бы применять их как коэффициенты при взвешивании, необходимо провести нормализацию [30, 31] по формуле (5).

$$w_{norm,i} = \frac{w_i}{\sum_{i=1}^{n} w_i}, \tag{5}$$

где n – это количество калькуляторов.

Нормализованные веса значений калькуляторов для нескольких уязвимостей представим в таблице 24.

Таблица 24 – Нормализованные веса калькуляторов

CVE	$w_{norm,1}$	$w_{norm,2}$	$w_{norm,3}$	$w_{norm,4}$
CVE-2025-21214	0,223702	0,218375	0,3249	0,233023
CVE-2019-1318	0,232421	0,323025	0,208194	0,23636
CVE-2024-42434	0,186667	0,262857	0,350476	0,2
CVE-2023-32016	0,249433	0,30839	0,249433	0,192744
CVE-2023-0597	0,274657	0,339576	0,0799	0,305868
CVE-2023-36908	0,273281	0,298507	0,212739	0,215472

Каждую нормированную оценку умножаем на соответствующий нормированный вес [30, 31] согласно формуле (6) и представляем взвешенные нормированные оценки в таблице 25:

$$S_{weighted} = S_{norm} * w_{norm,i}. \quad (6)$$

Таблица 25 – Взвешенные нормированные оценки уязвимостей

CVE	$S_{weighted,1}$	$S_{weighted,2}$	$S_{weighted,3}$	$S_{weighted,4}$
CVE-2025-21214	0,093955	0,089534	0,198189	0,101947
CVE-2019-1318	0,137128	0,264881	0,11003	0,141816
CVE-2024-42434	0,091467	0,181371	0,322438	0,105
CVE-2023-32016	0,137188	0,209705	0,137188	0,081916
CVE-2023-0597	0,151061	0,230911	0,012784	0,187344
CVE-2023-36908	0,177633	0,21194	0,107646	0,110429

После расчёта взвешенной оценки для каждого критерия, получим итоговую средневзвешенную оценку [30, 31] по формуле (7):

$$S_{final} = S_{weighted,1} + S_{weighted,2} + S_{weighted,3} + S_{weighted,4}. \quad (7)$$

Альтернативный подход для расчёта критичности наших уязвимостей – это использование среднеквадратичной оценки [30, 31], что можно рассчитать по формуле (8):

$$S_{final} = \sqrt{\frac{1}{n}\sum_{i=1}^{n} s_{norm,i}^2}. \quad (8)$$

Полученные через формулы (7) и (8) значения критичностей для некоторых уязвимостей представим в таблице 26:

Таблица 26 – Итоговые значения критичности

Идентификатор уязвимости	Итоговая средневзвешенная оценка	Итоговая среднеквадратичная оценка
CVE-2025-21214	0,483625166	0,47644681
CVE-2019-1318	0,653855525	0,644168505
CVE-2024-42434	0,70027619	0,677905783
CVE-2023-32016	0,565997732	0,558575196
CVE-2023-0597	0,582100499	0,539827808
CVE-2023-36908	0,607648623	0,601101541

Для дальнейших расчётов будет использоваться именно среднеквадратичная оценка. В отличие от средневзвешенного коэффициента, из-за возведения нормированных значений в квадрат усиливается влияние критических (крайне высоких) оценок. Это позволит без усреднения, адекватно отражать важность критических данных в контексте оценки каждого калькулятора. Проведём подсчёты значений критичности по показанным формулам для всех уязвимостей наших шаблонов атаки в таблицах 27-30.

Таблица 27 – Расчёт критичности уязвимостей CAPEC-329

Идентификатор уязвимости	Значение критичности
CVE-2025-21214	0,4764
CVE-2019-1318	0,6442
CVE-2024-42434	0,6779
CVE-2023-32016	0,5586
CVE-2023-0597	0,5398
CVE-2023-36908	0,6011
CVE-2023-24838	0,7726
CVE-2023-24901	0,7156
CVE-2022-34352	0,6556
CVE-2020-8832	0,5966
CVE-2024-26160	0,5139
CVE-2025-21308	0,6822
CVE-2023-29287	0,499
CVE-2024-21340	0,4414
CVE-2020-3347	0,6698
CVE-2019-1048	0,5278
CVE-2024-38030	0,6402
CVE-2020-3520	0,6028
CVE-2025-24071	0,7076
CVE-2025-21242	0,7403
CVE-2025-27736	0,5387
CVE-2023-32041	0,631
CVE-2023-35325	0,7885
CVE-2023-36889	0,5395
CVE-2024-30096	0,5815
CVE-2024-39823	0,6746
CVE-2021-39200	0,5155
CVE-2021-40690	0,6721
CVE-2021-39855	0,5512
CVE-2021-39856	0,5603
CVE-2021-39857	0,5513
CVE-2021-36192	0,5548
CVE-2021-34774	0,6165
CVE-2021-43536	0,5647
CVE-2021-45095	0,5228

Таблица 28 – Расчёт критичности уязвимостей для CAPEC-330

Идентификатор уязвимости	Значение критичности
CVE-2024-39822	0,6556
CVE-2021-44702	0,5463
CVE-2021-44739	0,477
CVE-2022-0281	0,7597
CVE-2022-21712	0,6512
CVE-2021-22785	0,6267
CVE-2021-45420	0,8491
CVE-2024-4008	0,763
CVE-2021-3677	0,5945
CVE-2022-0813	0,5247
CVE-2022-27241	0,6577
CVE-2021-28544	0,4644
CVE-2022-25166	0,5288
CVE-2022-20734	0,5706
CVE-2022-20664	0,6341
CVE-2024-50338	0,726
CVE-2022-33742	0,5588
CVE-2020-4159	0,7656
CVE-2022-35169	0,5437
CVE-2022-34659	0,6994
CVE-2021-3800	0,5919
CVE-2022-31143	0,5783
CVE-2022-31746	0,5996
CVE-2023-22875	0,7189
CVE-2022-43959	0,5299
CVE-2021-22786	0,6805
CVE-2024-47080	0,7155
CVE-2023-27478	0,5498
CVE-2023-0027	0,5183
CVE-2024-20457	0,6491
CVE-2023-0836	0,6955
CVE-2023-1258	0,6231
CVE-2023-29517	0,6062
CVE-2022-34352	0,6822

Таблица 29 – Расчёт критичности уязвимостей для CAPEC-331

Идентификатор уязвимости	Значение критичности
CVE-2023-3336	0,7426
CVE-2024-39912	0,6227
CVE-2024-36996	0,5446
CVE-2022-31248	0,5296
CVE-2022-22520	0,5612
CVE-2022-41697	0,5176
CVE-2023-32346	0,5086
CVE-2023-39343	0,6128
CVE-2023-40179	0,5893
CVE-2024-2482	0,5278
CVE-2023-33859	0,5768
CVE-2024-13028	0,5419
CVE-2024-13198	0,5720
CVE-2025-23214	0,6439
CVE-2022-20633	0,5922

Таблица 30 – Расчёт критичности уязвимостей для CAPEC-332

Идентификатор уязвимости	Значение критичности
CVE-2025-30280	0,5683
CVE-2023-49069	0,5502
CVE-2024-42343	0,6865
CVE-2024-35114	0,5171
CVE-2023-47159	0,5133
CVE-2023-37413	0,5469
CVE-2025-23193	0,5407
CVE-2025-1101	0,5974
CVE-2025-24023	0,5605
CVE-2025-2910	0,6
CVE-2025-31124	0,6005
CVE-2024-56476	0,5533
CVE-2025-30150	0,4665
CVE-2025-46736	0,4815
CVE-2021-37751	0,7095

3.2 Оценка рисков успешной реализации единичных вторжений и нахождение экстремальных сценариев атак для шаблонов CAPEC

Для дальнейшего расчёта рисков, связанных с единичными атаками, следует сначала определить значение ущерба, учитывающее различные свойства информации. Опираясь на методы, изложенные в работах [33,34], используем формулу (9):

$$U = 1 - (1 - U_{\text{к}})\big(1 - U_{\text{д}}\big)\big(1 - U_{\text{ц}}\big), \tag{9}$$

где $U_{\text{к}}$, $U_{\text{д}}$, $U_{\text{ц}}$ – коэффициенты, характеризующие ущерб конфиденциальности, доступности и целостности, соответственно [39].

Вероятность эксплуатации уязвимостей соответствующей техникой посчитаем по формуле (10):

$$P_{ij} = \frac{K_{ij}}{\sum_{z=1}^{m} K_{iz}}, \tag{10}$$

где K_{ij} – это значение критичности уязвимости j, эксплуатируемой техникой i; m – количество уязвимостей, эксплуатируемых техникой i [30-32].

Сформируем сводную таблицу данных для шаблона CAPEC-329. Техники эксплуатации уязвимостей и их критичности возьмем из таблиц 14 и 27 соответственно. Также посчитаем сопутствующий ущерб уязвимостей и вероятности успешной эксплуатации по формулам (9) и (10). Представим это в таблице 31:

Таблица 31 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-329

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимости
CAPEC-329	T1190	CVE-2019-1318	0,644168505	0,487240778	0,5
		CVE-2024-42434	0,677905783	0,512759222	0,5
	T1203	CVE-2023-32016	0,558575196	0,50853393	0,5
		CVE-2023-0597	0,539827808	0,49146607	0,5
		ИЛИ			
	T1059	CVE-2023-36908	0,601101541	0,437583318	0,5
		CVE-2023-24838	0,772583233	0,562416682	0,875
	T1068	CVE-2023-24901	0,715595731	0,382620675	0,5
		CVE-2022-34352	0,655572269	0,350526831	0,5
		CVE-2023-29287	0,499080467	0,266852494	0,2
		ИЛИ			
	T1055	CVE-2024-26160	0,513899819	0,286664106	0,5
		CVE-2025-21308	0,682153575	0,380519583	0,5
		CVE-2020-8832	0,596636405	0,332816311	0,5
	T1087	CVE-2024-21340	0,4413633	0,397201853	0,5
		CVE-2020-3347	0,669818072	0,602798147	0,5
	T1485	CVE-2019-1048	0,527753257	0,298036027	0,5
		CVE-2024-38030	0,64023025	0,361554718	0,5
		CVE-2020-3520	0,602786498	0,340409255	0,5

Визуализируем таблицу в виде графа атак с указанием вероятностей успешного использования дыр системы на рисунке 2:

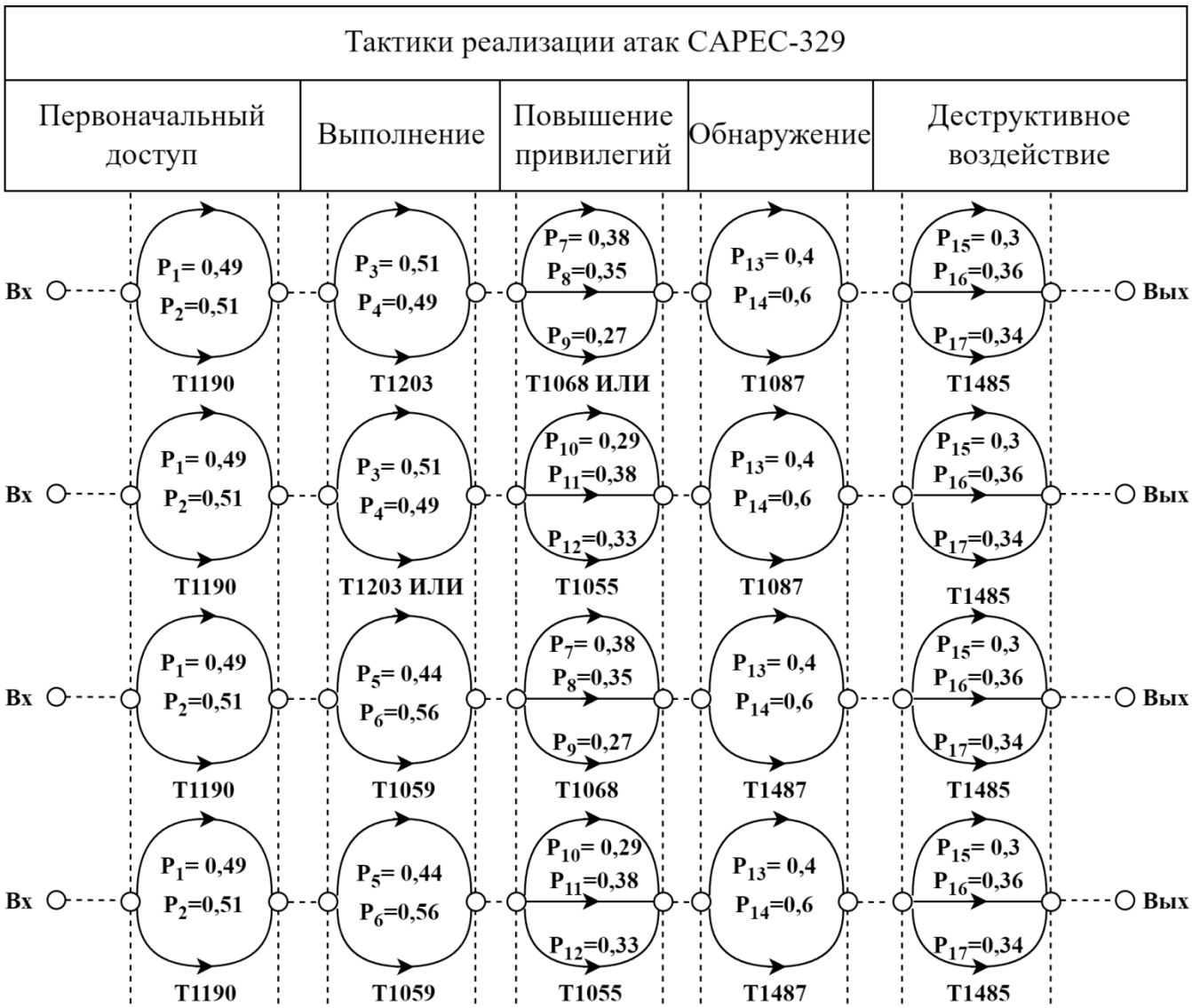


Рисунок 2 – Графовая модель вероятных сценариев реализации шаблона CAPEC-329

P_i – Вероятность успешной эксплуатации уязвимости.
Номера индексов соответствуют следующим уязвимостям:
1 - CVE-2019-1318; 2 - CVE-2024-42434; 3 - CVE-2023-32016;
4 - CVE-2023-0597; 5 - CVE-2023-36908; 6 - CVE-2023-24838;
7 - CVE-2023-24901; 8 - CVE-2022-34352; 9 - CVE-2023-29287;
10 - CVE-2024-26160; 11 - CVE-2025-21308; 12 - CVE-2020-8832;
13 - CVE-2024-21340; 14 - CVE-2020-3347; 15 - CVE-2019-1048;
16 - CVE-2024-38030; 17 - CVE-2020-3520

Используя формулу (11), можно произвести оценку риска [30-32, 39], возникающего при реализации избранного сценария шаблона CAPEC:

$$Risk_{\Sigma} = \prod_{i=1}^{k} P_i \times \sum_{j=1}^{k} U_j, \quad (11)$$

где P_i – вероятность эксплуатации i-ой уязвимости;

U_j – ущерб, наносимый атакуемой системе в результате эксплуатации j-ой уязвимости в ходе реализации техники;

k – количество используемых техник.

Согласно рисунку 2, имеем 288 возможных сценариев. Используя формулу (11) для каждого варианта, найдём экстремумы – самый вероятный сценарий, а также с наибольшей и наименьшей оценкой риска:

$$Risk_{max} = (0{,}51 * 0{,}56 * 0{,}38 * 0{,}5 * 0{,}36) * (0{,}5 + 0{,}875 + 0{,}5 + 0{,}5 + 0{,}5) = 0{,}068;$$
$$Risk_{min} = (0{,}49 * 0{,}44 * 0{,}27 * 0{,}4 * 0{,}3) * (0{,}5 + 0{,}5 + 0{,}2 + 0{,}5 + 0{,}5) = 0{,}0151.$$

Сценарий, имеющий наибольшую вероятность согласно рисунку 2, а также исходя из вычислений выше, наибольшую оценку риска представим на рисунке 3, а наименьшей на рисунке 4:

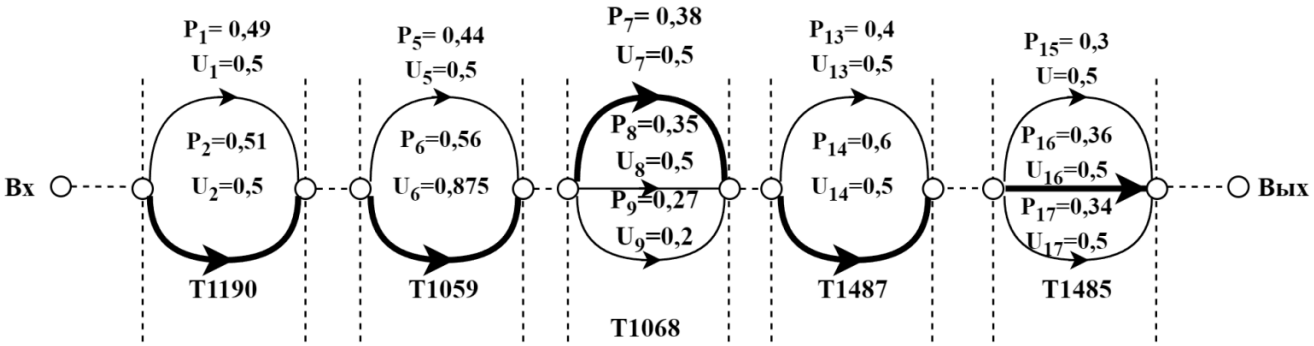


Рисунок 3 – Сценарий атаки шаблона CAPEC-329 с наибольшей оценкой риска

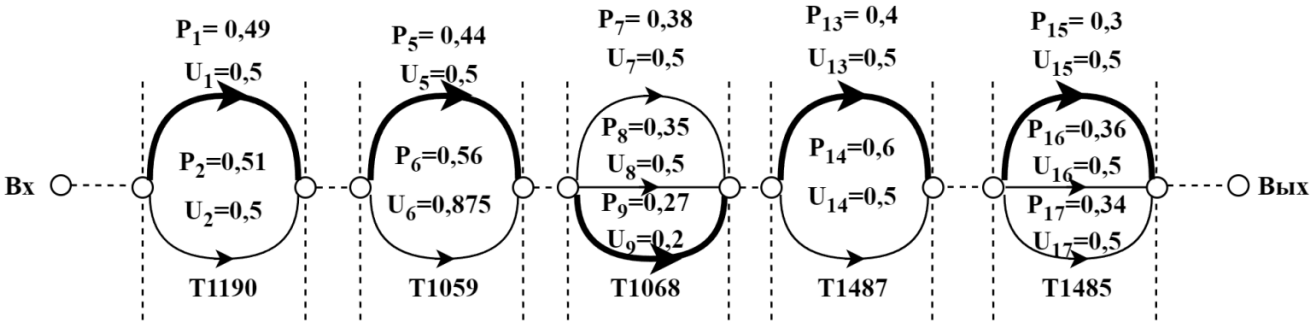


Рисунок 4 – Сценарий атаки шаблона CAPEC-329 с наименьшей оценкой риска

Запишем 10 сценариев для CAPEC-329, имеющих максимальную оценку риска, а также саму оценку в таблицу 32:

Таблица 32 – Сценарии шаблона CAPEC-329 с максимальной оценкой риска

Сценарий	Риск
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1068 (CVE-2023-24901) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0681
T1190 (CVE-2019-1318) → T1059 (CVE-2023-24838) → T1068 (CVE-2023-24901) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0655
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1055 (CVE-2024-26160) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0648
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1068 (CVE-2023-24901) → T1087 (CVE-2020-3347) → T1485 (CVE-2020-3520)	0.0644
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1068 (CVE-2024-39822) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0624
T1190 (CVE-2019-1318) → T1059 (CVE-2023-24838) → T1055 (CVE-2024-26160) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0622
T1190 (CVE-2019-1318) → T1059 (CVE-2023-24838) → T1068 (CVE-2023-24901) → T1087 (CVE-2020-3347) → T1485 (CVE-2020-3520)	0.0618
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1055 (CVE-2024-26160) → T1087 (CVE-2020-3347) → T1485 (CVE-2020-3520)	0.0612
T1190 (CVE-2019-1318) → T1059 (CVE-2023-24838) → T1068 (CVE-2024-39822) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0600
T1190 (CVE-2024-42434) → T1059 (CVE-2023-24838) → T1055 (CVE-2025-21308) → T1087 (CVE-2020-3347) → T1485 (CVE-2024-38030)	0.0593

Далее сделаем ту же работу для следующего шаблона атаки. Возьмём данные из таблиц 15 и 28 и представим соответствия параметров в таблице 33:

Таблица 33 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-330

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимости
CAPEC-330	T1595	CVE-2021-22786	0,680537471	0,567666	0,5
		CVE-2023-0027	0,518296489	0,432334	0,2
	T1190	CVE-2022-0281	0,759706851	0,302339	0,5
		CVE-2022-0813	0,524715697	0,20882	0,2
		CVE-2022-27241	0,657698449	0,261743	0,5
		CVE-2022-20734	0,570641087	0,227097	0,5
	T1068	CVE-2021-3800	0,591903708	0,528173	0,5
		CVE-2022-25166	0,528759693	0,471827	0,5
	T1555	CVE-2021-44702	0,54628113	0,302579	0,2
		CVE-2024-47080	0,715486067	0,396299	0,5
		CVE-2022-35169	0,543650853	0,301122	0,68
		ИЛИ			
	T1552	CVE-2024-50338	0,726000387	0,381104	0,5
		CVE-2022-43959	0,529929476	0,278179	0,5
		CVE-2024-20457	0,649061823	0,340716	0,5
	T1083	CVE-2022-34659	0,699362031	1	0,5
	T1005	CVE-2022-33742	0,558815712	0,308928	0,75
		CVE-2024-39822	0,655572269	0,362417	0,5
		CVE-2021-3677	0,594500894	0,328655	0,5
		ИЛИ			
	T1213	CVE-2020-4159	0,765649071	0,528802	0,5
		CVE-2022-34352	0,682243542	0,471198	0,5

Представим таблицу 33 в виде графа на рисунке 5:

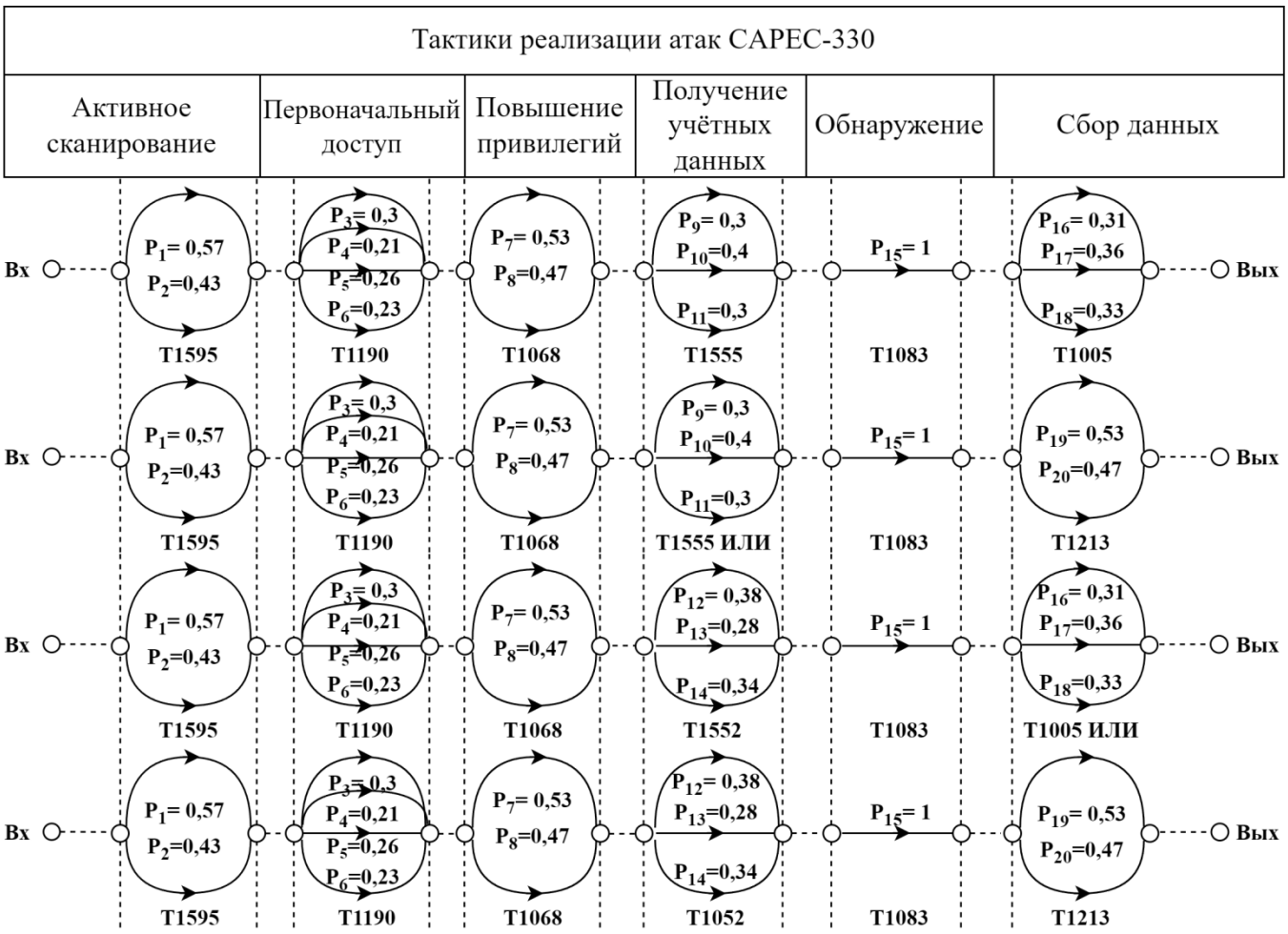


Рисунок 5 – Графовая модель вероятных сценариев реализации шаблона CAPEC-330

P_i – Вероятность успешной эксплуатации уязвимости.
Номера индексов соответствуют следующим уязвимостям:
1 - CVE-2021-22786; 2 - CVE-2023-0027; 3 - CVE-2022-0281;
4 - CVE-2022-0813; 5 - CVE-2022-27241; 6 - CVE-2022-20734;
7 - CVE-2021-3800; 8 - CVE-2022-25166; 9 - CVE-2021-44702;
10 - CVE-2024-47080; 11 - CVE-2022-35169; 12 - CVE-2024-50338;
13 - CVE-2022-43959; 14 - CVE-2024-20457; 15 - CVE-2022-34659;
16 - CVE-2022-33742; 17 - CVE-2024-39822; 18 - CVE-2021-3677;
19 - CVE-2020-4159; 20 - CVE-2022-34352

Получилось 480 возможных способов атаки. Согласно рисунку 5, наиболее вероятный сценарий: T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1552 (CVE-2024-50338) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159). Проведём расчёт оценки риска и после представим сам сценарий на рисунке 6:

$$Risk_{prob} = (0{,}57 * 0{,}3 * 0{,}53 * 0{,}38 * 1 * 0{,}53) * (0{,}5 * 5) = 0{,}0456.$$

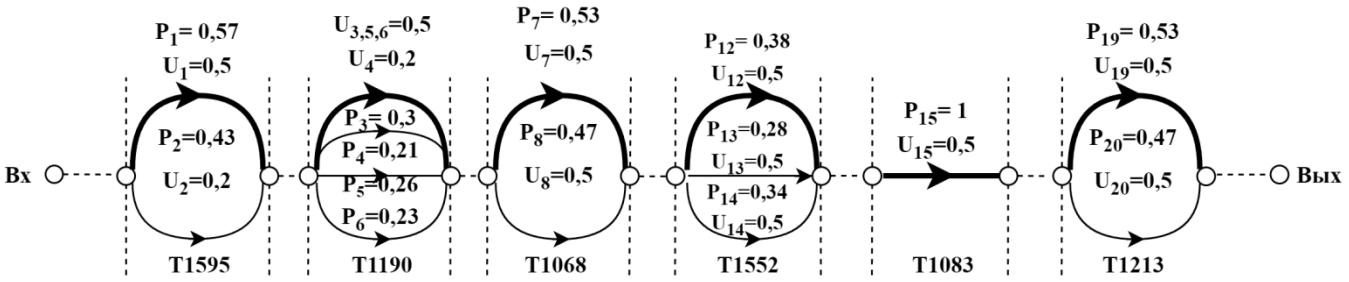


Рисунок 6 – Наиболее вероятный сценарий атаки шаблона CAPEC-330

Рассчитаем сценарии с наибольшей и наименьшей оценкой риска для CAPEC-330 и представим их на рисунках 7 и 8 соответственно:

$$Risk_{max} = (0{,}57 * 0{,}3 * 0{,}53 * 0{,}4 * 1 * 0{,}53) * (0{,}5 * 6) = 0{,}0551;$$
$$Risk_{min} = (0{,}43 * 0{,}21 * 0{,}47 * 0{,}3 * 1 * 0{,}47) * (0{,}5 * 3 + 0{,}2 * 3) = 0{,}01256.$$

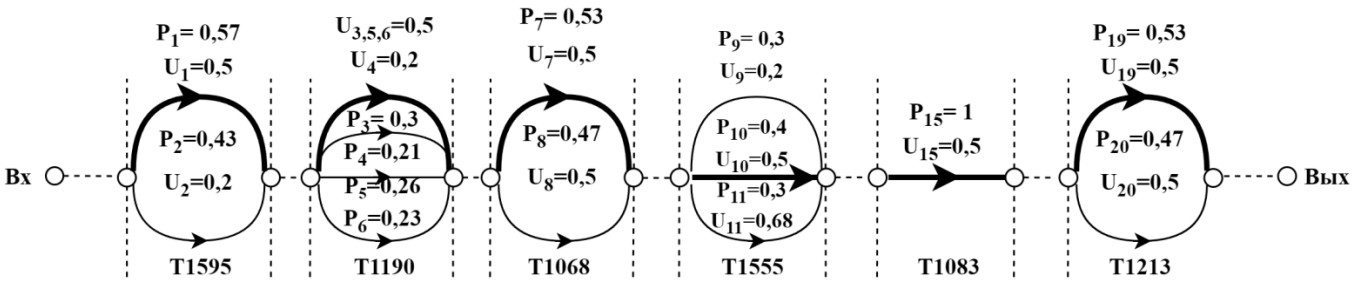


Рисунок 7 – Сценарий атаки шаблона CAPEC-330 с наибольшей оценкой риска

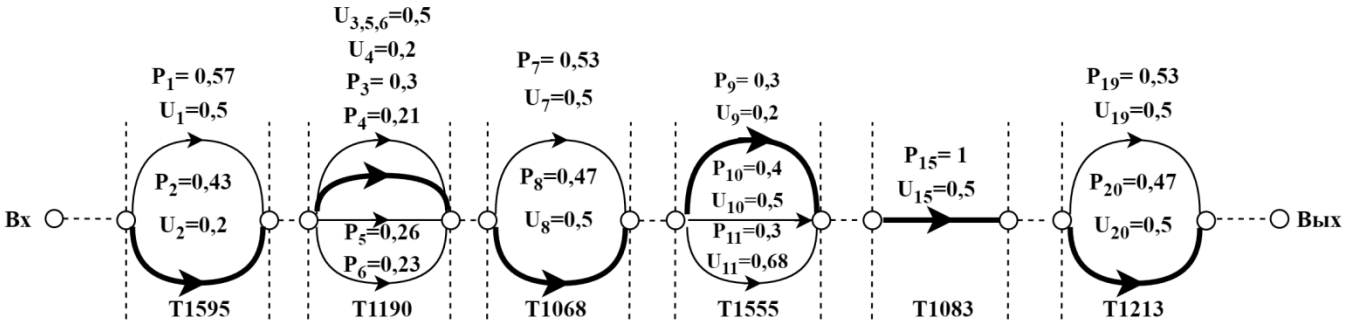


Рисунок 8 – Сценарий атаки шаблона CAPEC-330 с наименьшей оценкой риска

Десяток сценариев с максимальной оценкой риска представим в таблице 34:

Таблица 34 – Сценарии шаблона CAPEC-330 с максимальной оценкой риска

Сценарий	Риск
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1555 (CVE-2024-47080) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0551
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1552 (CVE-2024-50338) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0524
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2022-25166) → T1555 (CVE-2024-47080) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0493
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1555 (CVE-2024-47080) → T1083 (CVE-2022-34659) → T1213 (CVE-2022-34352)	0.0489
T1595 (CVE-2021-22786) → T1190 (CVE-2022-27241) → T1068 (CVE-2021-3800) → T1555 (CVE-2024-47080) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0478
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1552 (CVE-2024-20457) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0468
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2022-25166) → T1552 (CVE-2024-50338) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0468
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1552 (CVE-2024-50338) → T1083 (CVE-2022-34659) → T1213 (CVE-2022-34352)	0.0464
T1595 (CVE-2021-22786) → T1190 (CVE-2022-27241) → T1068 (CVE-2021-3800) → T1552 (CVE-2024-50338) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0454
T1595 (CVE-2021-22786) → T1190 (CVE-2022-0281) → T1068 (CVE-2021-3800) → T1555 (CVE-2022-35169) → T1083 (CVE-2022-34659) → T1213 (CVE-2020-4159)	0.0438

Далее разберём шаблон атаки CAPEC-331 и заполним сводную таблицу 35 по аналогии с предыдущими атаками:

Таблица 35 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-331

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимости
CAPEC-331	T1190	CVE-2024-36996	0,544617354	0,506973	0,2
		CVE-2022-31248	0,529635783	0,493027	0,2
		ИЛИ			
	T1078	CVE-2023-40179	0,58934418	0,507446	0,2
		CVE-2024-13198	0,57204813	0,492554	0,2
	T1059	CVE-2023-3336	0,742573397	0,543912	0,5
		CVE-2024-39912	0,622671914	0,456088	0,2
	T1562	CVE-2024-2482	0,527831649	0,46276	0,2
		CVE-2023-39343	0,612785648	0,53724	0,2
	T1110	CVE-2022-22520	0,561194318	0,520215	0,2
		CVE-2022-41697	0,517580006	0,479785	0,2
	T1021	CVE-2023-32346	0,50855801	0,441287	0,2
		CVE-2025-23214	0,643885908	0,558713	0,2
	T1041	CVE-2023-33859	0,576792044	0,515587	0,2
		CVE-2024-13028	0,54191789	0,484413	0,2
	T1486	CVE-2022-20633	0,592221717	1	0,2

Визуально представим таблицу 35 в виде графовой модели на рисунке 9:

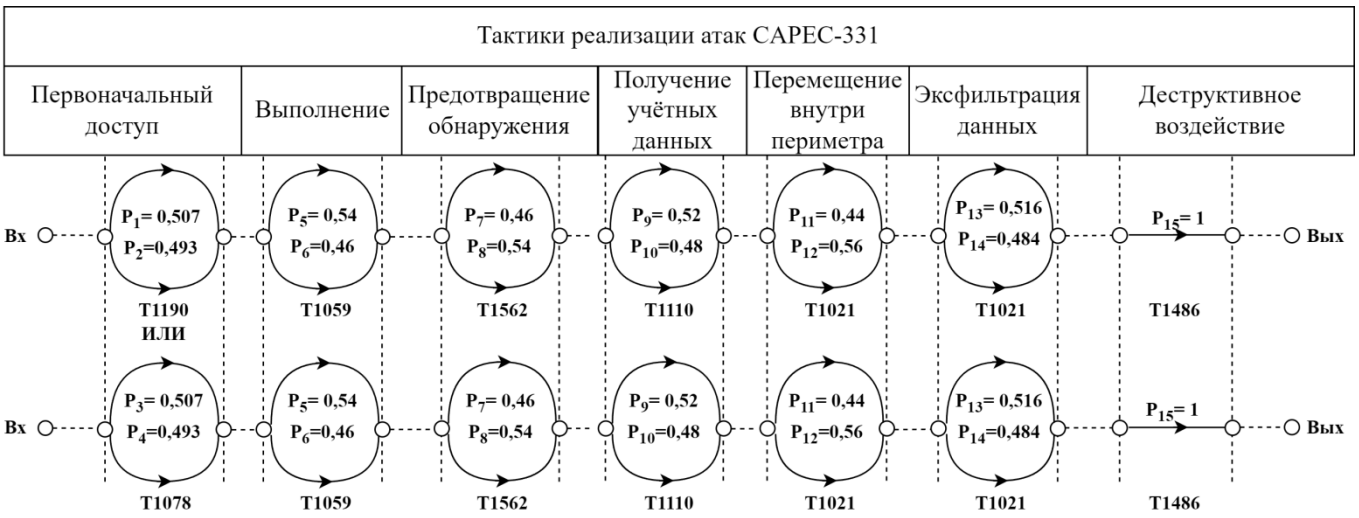


Рисунок 9 – Графовая модель вероятных сценариев реализации шаблона CAPEC-331

P_i – Вероятность успешной эксплуатации уязвимости.
Номера индексов соответствуют следующим уязвимостям:
1 - CVE-2024-36996; 2 - CVE-2022-31248; 3 - CVE-2023-40179;
4 - CVE-2024-13198; 5 - CVE-2023-3336; 6 - CVE-2024-39912;
7 - CVE-2024-2482; 8 - CVE-2023-39343; 9 - CVE-2022-22520;
10 - CVE-2022-41697; 11 - CVE-2023-32346; 12 - CVE-2025-23214;
13 - CVE-2023-33859; 14 - CVE-2024-13028; 15 - CVE-2022-20633

Имеем 128 возможных сценариев. Самый вероятный в тоже время является и самым рисковым из них. Рассчитаем риск и представим его на рисунке 10:

$$Risk_{max} = (0{,}507 * 0{,}54 * 0{,}54 * 0{,}52 * 0{,}56 * 0{,}516 * 1) * (0{,}2 * 6 + 0{,}5) = 0{,}0379.$$

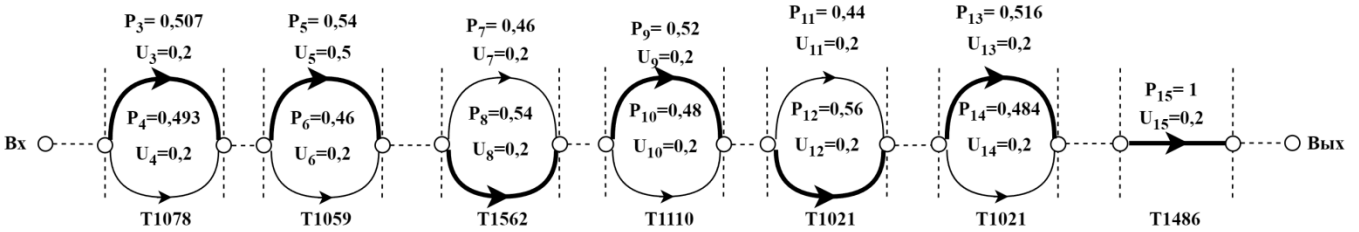


Рисунок 10 – Сценарий атаки шаблона CAPEC-331 с наибольшей оценкой риска

Используя формулу (11), найдём минимальный сценарий и представим его на рисунке 11:

$$Risk_{min} = (0{,}493 * 0{,}46 * 0{,}46 * 0{,}48 * 0{,}44 * 0{,}516 * 1) * (0{,}2 * 7) = 0{,}0159.$$

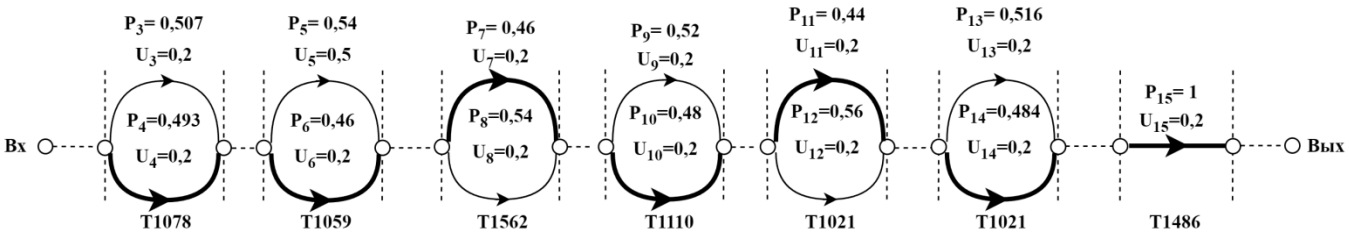


Рисунок 11 – Сценарий атаки шаблона CAPEC-331 с наименьшей оценкой риска

Самые важные сценарии представим в таблице 36:

Таблица 36 – Сценарии шаблона CAPEC-331 с максимальной оценкой риска

Сценарий	Риск
T1078 (CVE-2023-40179) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0379
T1190 (CVE-2024-36996) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0378
T1190 (CVE-2022-31248) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0368
T1078 (CVE-2024-13198) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0368
T1078 (CVE-2023-40179) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2024-13028) → T1486 (CVE-2022-20633)	0.0355
T1190 (CVE-2024-36996) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2024-13028) → T1486 (CVE-2022-20633)	0.0355
T1078 (CVE-2023-40179) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-41697) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0350
T1190 (CVE-2024-36996) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-41697) → T1021 (CVE-2025-23214) → T1041 (CVE-2023-33859) → T1486 (CVE-2022-20633)	0.0349
T1190 (CVE-2022-31248) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2024-13028) → T1486 (CVE-2022-20633)	0.0345
T1078 (CVE-2024-13198) → T1059 (CVE-2023-3336) → T1562 (CVE-2023-39343) → T1110 (CVE-2022-22520) → T1021 (CVE-2025-23214) → T1041 (CVE-2024-13028) → T1486 (CVE-2022-20633)	0.0345

Проделаем подобную работу со следующим шаблоном. Соберём имеющиеся данные по шаблону CAPEC-332 в таблицу 37 и визуализируем её на рисунке 12:

Таблица 37 – Соответствие параметров вероятных сценариев реализации кибератаки шаблона CAPEC-332

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимости
CAPEC-332	T1595	CVE-2025-30280	0,568336388	1	0,2
	T1078	CVE-2025-24023	0,560458796	1	0,2
		ИЛИ			
	T1190	CVE-2024-35114	0,517083165	0,311233	0,2
		CVE-2023-37413	0,546900357	0,32918	0,2
		CVE-2025-1101	0,597416312	0,359586	0,2
	T1574.002	CVE-2021-37751	0,709455117	1	0,5
	T1562.001	CVE-2023-49069	0,550164748	0,478143	0,2
		CVE-2025-31124	0,600463363	0,521857	0,2
	T1087.001	CVE-2024-42343	0,686481063	0,587726	0,2
		CVE-2025-46736	0,481548609	0,412274	0,2
	T1041	CVE-2025-2910	0,599970051	0,562556	0,2
		CVE-2025-30150	0,46653644	0,437444	0,2
	T1499	CVE-2023-47159	0,513336208	0,319372	0,2
		CVE-2024-56476	0,55332094	0,344249	0,2
		CVE-2025-23193	0,540672325	0,336379	0,2

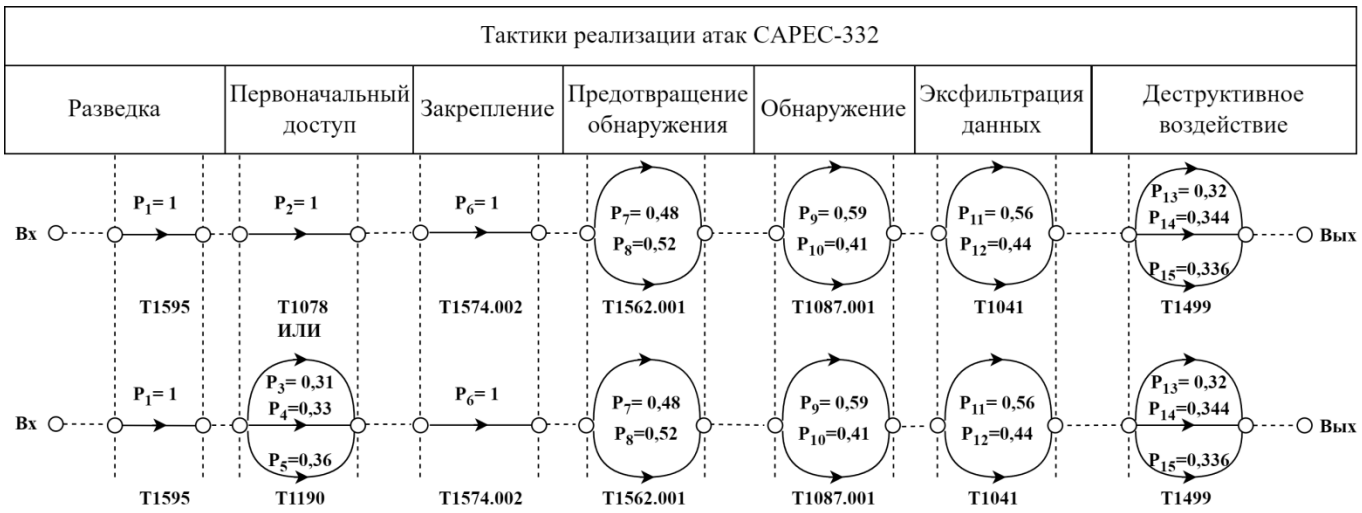


Рисунок 12 – Графовая модель вероятных сценариев реализации шаблона CAPEC-332

P_i – Вероятность успешной эксплуатации уязвимости.
Номера индексов соответствуют следующим уязвимостям:
1 - CVE-2025-30280; 2 - CVE-2025-24023; 3 - CVE-2024-35114;
4 - CVE-2023-37413; 5 - CVE-2025-1101; 6 - CVE-2021-37751;
7 - CVE-2023-49069; 8 - CVE-2025-31124; 9 - CVE-2024-42343;
10 - CVE-2025-46736; 11 - CVE-2025-2910; 12 - CVE-2025-30150;
13 - CVE-2023-47159; 14 - CVE-2024-56476; 15 - CVE-2025-23193

Получилось 96 сценариев. Самый вероятный из них снова оказывается с максимальной оценкой риска. Покажем данный расчёт и представим на рисунке 13:

$$Risk_{max} = (1 * 1 * 1 * 0{,}52 * 0{,}59 * 0{,}56 * 0{,}344) * (0{,}2 * 6 + 0{,}5) = 0{,}1011.$$

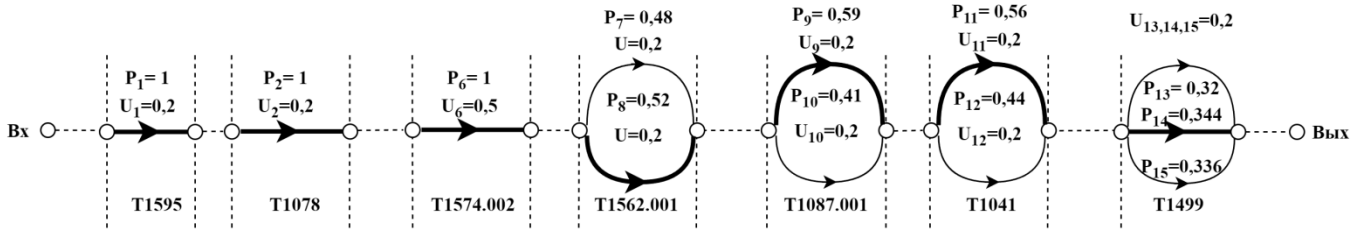


Рисунок 13 – Сценарий атаки шаблона CAPEC-332 с наибольшей оценкой риска

Для минимальной оценки риска посчитаем его и проиллюстрируем на рисунке 14. Максимальные же оценки представим в таблице 38:

$$Risk_{min} = (1 * 0{,}31 * 1 * 0{,}48 * 0{,}41 * 0{,}44 * 0{,}32) * (0{,}2 * 6 + 0{,}5) = 0{,}146.$$

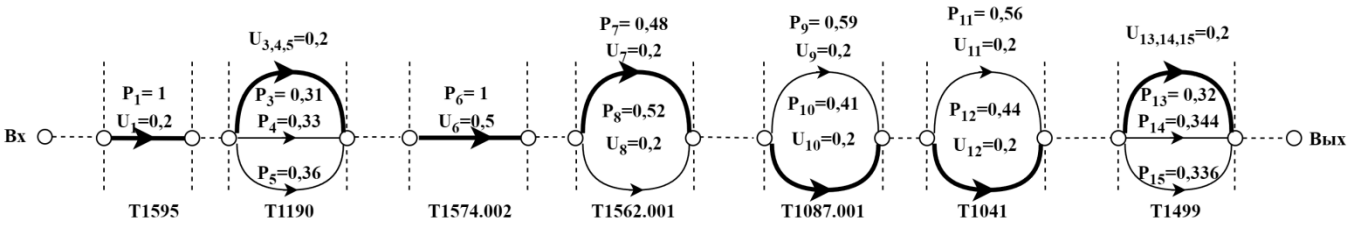


Рисунок 14 – Сценарий атаки шаблона CAPEC-332 с наименьшей оценкой риска

Таблица 38 – Сценарии шаблона CAPEC-332 с максимальной оценкой риска

Сценарий	Риск
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2024-56476)	0.1011
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2025-23193)	0.0987
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2023-47159)	0.0940
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2023-49069) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2024-56476)	0.0925
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2023-49069) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2025-23193)	0.0904
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2023-49069) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-2910) → T1499 (CVE-2023-47159)	0.0861
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-30150) → T1499 (CVE-2024-56476)	0.0784
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-30150) → T1499 (CVE-2025-23193)	0.0766
T1595 (CVE-2025-30280) → T1078 (CVE-2025-24023) → T1574.002 (CVE-2021-37751) → T1562.001 (CVE-2025-31124) → T1087.001 (CVE-2024-42343) → T1041 (CVE-2025-30150) → T1499 (CVE-2023-47159)	0.0730

4 Разработка организационных регламентов для устранения уязвимостей и регулирования рисков кибератак класса «Генерация сообщений об ошибке ICMP»

Помимо прогнозирования возможных действий злоумышленника в будущих атаках на автоматизированные системы, необходимо разработать методы реагирования и ликвидации инцидентов для смягчения потенциального ущерба в дальнейшем. Для создания организационных регламентов [4-8], воспользуемся описанием уязвимостей из БДУ ФСТЭК России [16], а также международным стандартом по информационной безопасности, предоставляющим рекомендации по управлению информационной безопасностью ISO/IEC 27002 [41]. Регламенты для CAPEC-329 представлю на таблице 39. Регламенты для других шаблонов атак представлены в Приложении Б.

Таблица 39 – Организационные регламенты CAPEC-329

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	На этапе первоначального доступа (T1190) в случае CVE-2019-1318 это уязвимость Exim SMTP, когда вредоносный SMTP-пакет позволяет обойти проверку формата адресов. В случае уязвимости CVE-2024-42434 представляет собой эксплуатацию в компоненте Oracle WebLogic.	1. Заблокировать все входящие запросы и подозрительные IP-адреса с помощью межсетевого экрана. 2. Изолировать уязвимый сервер в сегмент сети без доступа к остальным сервисам.	1. Установить официальные обновления Oracle WL, закрывающие CVE-2024-42434. 2. Обновить IDS/IPS-подписи и правила WAF для обнаружения эксплойтов.

Продолжение таблицы 39

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
		3. Завершить все активные сеансы и сбросить временные токены аутентификации.	3. Проверить конфигурацию JVM, отключить неиспользуемые компоненты.
Выполнение	На этапе выполнения (T1203 и T1059) уязвимость CVE-2023-32016 позволяет с помощью сетевого запроса загрузить и исполнить злонамеренный модуль. CVE-2023-36908 представляет собой атаку на ПО Microsoft Exchange.	1. Отключить пострадавшие сервера обмена от сети. После проанализировать их. 2. Завершить все активные PowerShell-процессы, отключить учётные записи, участвовавшие в атаке на сервер. 3. Проверить журналы на предмет внедрённых правил пересылки или чужих подписей в письмах.	1. Применить обновления, в которых устранены CVE-2023-32016 и CVE-2023-36908. 2. Сбросить пароли и перевыпустить сертификаты для учётных записей для критичных служб. 3. Ограничить доступ к настройкам учётных записей только доверенным IP-диапазонам через брандмауэр или прокси, отключить прямой доступ к портам 443/993 для внешних клиентов.

Продолжение таблицы 39

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привилегий	В рамках повышения привилегий (T1068 и T1055): CVE-2023-24901 реализуется через подмену DLL файла. CVE-2024-39822 позволяет подменить драйвер. CVE-2024-26160 связан с API Windows. CVE-2025-21308 - инсталлятор MSI.	1. Завершить все активные процессы. 2. Сохранить логи Windows Security (Event ID 1001, 7045) и Application на машине для подтверждения факта подмены DLL. 3. Проверить целостность системных файлов.	1. Установить официальное обновление Microsoft, закрывающее уязвимости. 2. Вручную удалить вредоносные DLL файлы. 3. Проверить и восстановить из резервных копий.
Обнаружение	На этапе обнаружения учётных записей (T1087) злоумышленник использовал CVE-2024-21340 для перебора учётных записей, отправляя специально сконструированные запросы.	1. Завершить все подозрительные сессии и переконфигурировать доверенные каналы. 2. Настроить многофакторную аутентификацию для всех административных учётных записей. 3. Установить оповещение в системе защиты на резкий рост числа операций чтения атрибутов.	1. Установить обновления для Active Directory, закрывающие CVE-2024-21340, и убедиться, что контроллеры домена работают на новейшей версии ОС. 2. Внедрить постоянный аудит перебора записей.

Продолжение таблицы 39

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Деструктивное воздействие	На этапе деструктивного воздействия (T1485) CVE-2019-1048 позволяет уничтожить метаданные резервных копий в Linux. Уязвимость CVE-2024-38030 позволяет злоумышленнику через вредоносный драйвер перезаписать разделы дисков компьютера.	1. При обнаружении признаков перезаписи разделов, отключить диск от сети. 2. С помощью загрузочного носителя и безопасного режима, найти и удалить вредоносный драйвер.	1. Восстановить разделы диска из резервной копии. 2. Использовать инструменты для восстановления повреждённых системных файлов. 3. Включить UEFI Secure Boot и Trusted Boot.

ЗАКЛЮЧЕНИЕ

В ходе проведённого исследования была достигнута цель: повышение защищённости АИС от кибератак класса «Генерация сообщений об ошибке ICMP» за счёт риск-анализа сценариев их реализации. Получены следующие результаты:

− структурированная база данных кибератак класса «Генерация сообщений об ошибке ICMP» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

− векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

− методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Генерация сообщений об ошибке ICMP», с учётом специфики используемых злоумышленником сценариев;

− комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Генерация сообщений об ошибке ICMP» на уязвимости АИС.

Результаты подчёркивают значимость интеграции CAPEC-шаблонов атаки, техник MITRE ATT&CK и данных о CVE-уязвимостях в единую систему анализа киберугроз. Такой подход позволит глубже понять потенциал злоумышленников, использующих атаки класса «Генерация сообщений об ошибке ICMP», и выработать более точные и своевременные стратегии защиты.

Полученные оценки рисков помогут аналитикам сосредоточить своё внимание на наиболее эксплуатируемые и самые критичные уязвимости, благодаря чему качественнее распределять имеющиеся ресурсы.

Составленные сценарии возможных атак показывают недостатки механизмов защиты в АИС. Это всевозможные узкие места, которые можно исправить обновлением ПО, правильной настройкой брандмауэра или же фильтрацией ICMP-трафика. Найденные сценарии с максимальным значением риска и самые вероятные

должны стать первичными целями для реагирования эксперта по информационной безопасности.

Разработанные организационные регламенты определяют необходимые меры первичного реагирования на инциденты, а также меры ликвидации последствий. Выполнение данных действий позволит проанализировать сеть после произошедшей атаки, исправить повреждения и настроить защитные механизмы для невозможности повторения этой атаки в будущем.

Проведённое исследование показало, что повышение безопасности АИС от атак класса «Генерация сообщений об ошибке ICMP» требует комплексного подхода, сочетающего анализ уязвимостей, формирование сценариев атак и количественную оценку их вероятности и ущерба. Разработанная методология позволяет не только оценивать потенциальные потери, но и выбирать наиболее эффективные меры противодействия – от назначения правил фильтрации трафика до внедрения процедур мониторинга аномалий и регламентов реагирования.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 Актуальные киберугрозы. – Электрон. Дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/aktualnye-kiberugrozy-iv-kvartal-2024-goda-i-kvartal-2025-goda/. – Текст: электронный.

10 CAPEC. – Электрон. Дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

11 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

12 PT Security MITRE. – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

13 MITRE EMB3D. – Электрон. дан. – Режим доступа: https://emb3d.mitre.org/. – Текст: электронный.

14 ATLAS MITRE. – Электрон. дан. – Режим доступа: https://atlas.mitre.org/. – Текст: электронный.

15 ATLAS SecurityHub. – Электрон. дан. – Режим доступа: https://atlas.securityhub.ru/. – Текст: электронный.

16 База данных угроз ФСТЭК (BDU). – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

17 Центр безопасности данных. – Электрон. Дан. – Режим доступа: https://data-sec.ru/personal-data/threats-data-bank. – Текст: электронный.

18 Национальный координационный центр по компьютерным инцидентам. – Электрон. дан. – Режим доступа: https://cert.gov.ru/. – Текст: электронный.

19 NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

20 CVE. – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

21 CVSS. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/. – Текст: электронный.

22 CVSS v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3-1/. – Текст: электронный.

23 CVSS v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4-0/. – Текст: электронный.

24 EPSS. – Электрон. дан. – Режим доступа: https://www.first.org/epss. – Текст: электронный.

25 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-risk-rating.com/. – Текст: электронный.

26 Калькулятор CISA SSVC. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

27 Калькулятор VISS CVSS. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/. – Текст: электронный.

28 Halborn BVSS. – Электрон. дан. – Режим доступа: https://www.halborn.com/bvss. – Текст: электронный.

29 HVSS Online. – Электрон. дан. – Режим доступа: https://hvss.online/. – Текст: электронный.

30 Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А. А. Остапенко, В. П. Шелякин, Е. С. Короткова [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 521-542. – Текст: непосредственный.

31 Остапенко, А. А. Актуальные задачи и некоторые их решения в части риск-калькуляции успешности реализации единичных кибератак / А. А. Остапенко // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 543-552. – Текст: непосредственный.

32 Остапенко, А. А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А. А. Остапенко // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 401-420. – Текст: непосредственный.

33 Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 7-30. – Текст: непосредственный.

34 Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 1. – С. 31-54. – Текст: непосредственный.

35 Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 319-338. – Текст: непосредственный.

36 Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 3. – С. 339-378. – Текст: непосредственный.

37 Нейросетевой сервис регламентации мер противодействия кибератакам (часть III) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 477-488. – Текст: непосредственный.

38 Нейросетевой сервис регламентации мер противодействия кибератакам (часть IV) / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 4. – С. 489-508. – Текст: непосредственный.

39 Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 219-230. – Текст: непосредственный.

40 Формализация знаний и данных кибератак и уязвимостей / Г. А. Остапенко, А. П. Васильченко, А. А. Остапенко [и др.] // Информация и безопасность. – 2024. – Т. 27, № 2. – С. 231-238. – Текст: непосредственный.

41 Стандарт ISO/IEC 27002:2013 https://docs.cntd.ru/document/1200179669. – Электрон. дан. – Режим доступа: https://hvss.online/. – Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица А1 – Паспорт уязвимости CVE-2025-21214

Идентификатор уязвимости	CVE-2025-21214 Уязвимость в компоненте BitLocker. Обусловлена недостаточной защитой служебных данных. Эксплуатация этой уязвимости может дать возможность получить доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:P/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А2 – Паспорт уязвимости CVE-2024-42434

Идентификатор уязвимости	CVE-2024-42434 Уязвимость в программном обеспечении Zoom. Связана с недочетами в защите служебной информации. Эксплуатация уязвимости способна дать нарушителю возможность получить доступ к информации, подлежащей защите.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А3 – Паспорт уязвимости CVE-2023-32016

Идентификатор уязвимости	CVE-2023-32016 Уязвимость, обнаруженная в Windows Instlaller, вызвана недостаточной защитой служебной информации. В случае успешной эксплуатации, может дать доступ к защищаемый данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А4 – Паспорт уязвимости CVE-2023-0597

Идентификатор уязвимости	CVE-2023-0597 Уязвимость в механизме управления памятью, применяемом ядром операционной системы Linux, связана с отсутствием случайного перебора стеков, используемых при обработке исключений. Эксплуатация данной уязвимости позволяет получить несанкционированный доступ к информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А5 – Паспорт уязвимости CVE-2023-36908

Идентификатор уязвимости	CVE-2023-36908 Уязвимость, обнаруженная в системе Hyper-V, связана с отсутствием защиты служебных данных. Использование данной уязвимости может привести к несанкционированному доступу к конфиденциальным данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А6 – Паспорт уязвимости CVE-2023-24838

Идентификатор уязвимости	CVE-2023-24838 Уязвимость в системе распределения нагрузки PowerStation, которая обусловлена отсутствием проверки подлинности при обращении к критически важной функциональности. Причиной этому служит недостаточная защита данных. Использование данной уязвимости предоставляет доступ к конфиденциальной информации. Кроме того, это может привести к возможности выполнения произвольного кода или вызову отказа в обслуживании.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А7 – Паспорт уязвимости CVE-2023-24901

Идентификатор уязвимости	CVE-2023-24901 Уязвимость, обнаруженная в компоненте Windows NFS Portmapper. Связана с отсутствием защиты конфиденциальной информации. Эксплуатация предоставляет нарушителю, получившему удаленный доступ, возможность раскрытия данных, подлежащих защите.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А8 – Паспорт уязвимости CVE-2021-36192

Идентификатор уязвимости	CVE-2021-36192 Уязвимость в программном обеспечении для централизованного администрирования FortiManager от Fortinet связана с утечкой информации в ошибочном участке памяти. Эксплуатация уязвимости может предоставить злоумышленнику возможность получения доступа к конфиденциальным данным.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 3,2)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А9 – Паспорт уязвимости CVE-2021-34774

Идентификатор уязвимости	CVE-2021-34774 Уязвимость веб-интерфейса, ответственного за управление, в Cisco Common Services Platform Collector. Она связана с некорректным поведением при обработке корректных API-запросов, касающихся сбора данных в сети. Эксплуатация уязвимости позволяет удаленно получить доступ к конфиденциальной информации путем отправки HTTP-запроса.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А10 – Паспорт уязвимости CVE-2021-43536

Идентификатор уязвимости	CVE-2021-43536 Уязвимость, обнаруженная в Mozilla Firefox и Mozilla Thunderbird, касается утечки информации. Эксплуатация уязвимости может дать возможность получить доступ к конфиденциальной информации через специально сгенерированную веб-страницу.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А11 – Паспорт уязвимости CVE-2021-45095

Идентификатор уязвимости	CVE-2021-45095 Уязвимость функции pep_sock_accept, входящей в состав ядра Linux. Она обусловлена слабым уровнем защиты служебных данных. Использование уязвимости может предоставить несанкционированный доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А12 – Паспорт уязвимости CVE-2024-36996

Идентификатор уязвимости	CVE-2024-36996 Уязвимость в реализации стандарта Security Assertion Markup Language на платформе Splunk Enterprise, предназначенной для операционного анализа, обусловлена некорректной обработкой ответов на входящие запросы. Эксплуатация данной уязвимости предоставляет возможность реализации метода «грубой силы».
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А13 – Паспорт уязвимости CVE-2022-41697

Идентификатор уязвимости	CVE-2022-41697 Уязвимость, обнаруженная в CMS Ghost, основывается на некорректной обработке входящих запросов. Использование этой уязвимости позволяет получить возможность извлечения конфиденциальной информации. Для этого требуется отправка специально сконструированного HTTP-запроса.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А14 – Паспорт уязвимости CVE-2022-20633

Идентификатор уязвимости	CVE-2022-20633 Уязвимость, затрагивающая веб-интерфейс, который используется для управления Cisco Enterprise Chat and Email, обусловлена неправильным сопоставлением ответов на полученные запросы. Использование уязвимости может позволить злоумышленнику, действующему удаленно, несанкционированно извлекать конфиденциальную информацию, путем специальных запросов.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А15 – Паспорт уязвимости CVE-2023-49069

Идентификатор уязвимости	CVE-2023-49069 Уязвимость в базовом механизме аутентификации среды выполнения Mendix Runtime. Данная уязвимость связана с отличающимися ответами сервиса. На запросы нарушитель, действующий удалённо, получает несанкционированный доступ к защищаемой информации.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А16 – Паспорт уязвимости CVE-2024-42343

Идентификатор уязвимости	CVE-2024-42343 Уязвимость ПО аналитики кампании Loway QueueMetrics, связанная с отличающимися ответами на запросы. Эксплуатация уязвимости даёт возможность злоумышленнику, работающему удалённо, получить доступ к защищённой информации путём отправки специальных запросов.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А17 – Паспорт уязвимости CVE-2024-35114

Идентификатор уязвимости	CVE-2024-35114 Уязвимость в ПО IBM Control Center (система мониторинга и управления процессами) позволяет нарушителю получить доступ к защищаемой информации. Связана с несоответствием ответов на входящие запросы.
Идентификатор типа ошибки	CWE-204
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

ПРИЛОЖЕНИЕ Б

Таблица Б1 – Организационные регламенты CAPEC-330

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Активное сканирование	На этапе разведки (T1595) злоумышленники могут использовать уязвимости CVE-2021-22786 и CVE-2023-0027, обе являются дырами в ПО Modbus TCP сервера, соответственно позволяют посылать специально сконструированные запросы для чтения памяти устройств.	1. Включить сигнатуры подобных Modbus запросов в системы защиты от вторжений. 2. Проверить логи сети на аномальное количество Modbus-запросов и заблокировать подозрительные IP. 3. Ограничить доступ к Modbus-TCP только доверенным подсетям.	1. Обновить прошивку контроллеров до новейших версий (закрывающих уязвимости). 2. Настроить сетевой экран на блокировку доступности TCP порта 502 из незащищенной зоны. 3. Провести аудит конфигурации сети и сегментировать.
Первоначальный доступ	Все 4 уязвимости в технике T1190 приводят к утечке данных или обходу авторизации.	1. Изолировать пострадавшие веб-сервисы и отключить доступ к внешней сети. 2. Сохранить логи для поиска инструментов для взлома. 3. Заблокировать в брандмауэре все нестандартные параметры.	1. Установить официальные обновления для Microweber (CVE-2022-0281) версии 1.2.11 и выше, phpMyAdmin (CVE-2022-0813) версии 5.1.2 и выше, новейшую версию Mendix Apps (CVE-2022-27241) и Cisco vManage (CVE-2022-20734). 2. Сбросить пароли и перевыпустить сертификаты. 3. Восстановить приложения из резервных копий и провести тесты безопасности.

Продолжение таблицы Б1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привилегий	На этом этапе (T1068) происходит утечка файлов через уязвимость CVE-2021-3800 из-за неправильной кодировки, а также кража Net-хешей (CVE-2022-25166). Это позволяет поднимать права до root/SYSTEM в операционных системах.	1. Немедленно завершить подозрительные процессы pkexec и OpenVPN. 2. Сохранить логи системной безопасности. 3. Проверить подписи загруженных файлов и драйверов.	1. Обновить Glib до версии 2.63.6 и новее, а также AWS VPN Client до новейшей версии, где исправили уязвимость. 2. Удалить неподписанные файлы и драйверы. 3. Восстановить конфигурацию прав данных приложений.
Получение учётных данных	Техника T1555 эксплуатирует уязвимости CVE-2021-44702 (извлечение паролей), CVE-2024-47080 (чтение хэшей), CVE-2022-35169 (доступ к секретам) – всё это позволяет добывать хеши и тексты паролей из хранилищ.	1. Завершить сессии пользователей и выйти из задействованных учётных записей. 2. Собрать логи и просканировать на подозрительную активность. 3. Запустить сканирование для поиска подозрительных флеш-модулей.	1. Обновить операционную систему для закрытия всех трёх уязвимостей. 2. Сбросить пароли административных учётных записей, а также серверных. 3. Пересоздать защищённые хранилища и перевыпустить ключи и сертификаты.
	В технике T1552 имеем уязвимости CVE-2024-50338, CVE-2022-43959 (пароли в логах), CVE-2024-20457 (незашифрованное хранение токенов), что дают прямой доступ к паролям.	1. Остановить приложение и деактивировать раскрытые ключи. 2. Сохранить копии конфигураций для аудита. 3. Проверить журналы доступа на подозрительные запросы.	1. Перейти на версии ПО, где было улучшено хранение паролей (это закроет все три уязвимости). 2. Пересоздать пароли и токены. 3. Удалить данные пострадавших учётных записей из конфигурационных файлов и внедрить безопасные шаблоны.

Продолжение таблицы Б1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Обнаружение	Техника T1083 представляет собой изучение файлов и каталогов. Уязвимости дают доступ к локальным данным.	1. Заблокировать подозрительные PowerShell-сессии и ограничить их. 2. Сохранить логи PowerShell. 3. Проанализировать сетевые логи.	1. Обновить Windows и PowerShell до версий, закрывающей CVE-2022-34659. 2. Ввести групповые политики. 3. Пересмотреть права доступа и внедрить фильтрацию.
Сбор данных	Все 3 уязвимости в технике T1005 приводят к эксплуатации драйверов и сервисов, а после к незаконному доступу к локальным данным.	1. Приостановить подозрительные драйверы или сервисы и выгрузить их из ядра. 2. Сохранить логи. 3. Проанализировать процессы, открывающие файлы, что не должны быть доступны.	1. Обновить операционные системы до версий, в которых исправлены CVE. 2. Восстановить файлы из резервных копий. 3. Настроить политики загрузки драйверов и права доступа к системе.
	Техника T1213 ведёт за собой извлечение информации из баз данных из-за массовых вызовов SELECT с синтаксическими аномалиями.	1. Перевести БД в режим расследования. 2. Сохранить логи СУБД и журналы веб-приложения. 3. Проверить брандмауэр на существование аномалий SQL-трафика.	1. Установить патчи для закрытия уязвимостей. 2. Пересоздать учётные записи БД и сменить пароли. 3. Внедрить защиту от SQL-инъекций с помощью запросов с параметрами.

Таблица Б2 – Организационные регламенты CAPEC-331

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Уязвимости техники T1190 ведут за собой компрометацию веб-приложений и получение первоначального доступа. Техника T1078 ведёт к несанкционированному входу под легитимными учётками, обходу аутентификации.	1. Отключить доступ к критичным модулям и переключить сами модули в режим расследования. 2. Отключить форму восстановления пароля для дальнейшего обслуживания. 3. Сохранить логи для последующего анализа. 4. Заблокировать подозрительные IP-адреса через брандмауэр.	1. На время исправления ошибок, добавить универсальный ответ сервера на попытки доступа к данным. 2. Установить патчи для всех уязвимостей из техник T1190 и T1078. 3. Реализовать многофакторную аутентификацию.
Выполнение	В технике T1059 злоумышленники используют командные строки PowerShell, Bash, Python и др. для запуска вредоносного кода.	1. Приостановить все веб-сервисы, затронутые при атаке. 2. Сохранить HTTP-логи с аномальными запросами к форме восстановления пароля. 3. Проверить наличие скрипт-ботов по перебору паролей.	1. Установить патчи для ПО, устраняющие уязвимости CVE-2023-3336 и CVE-2024-39912. 2. Внедрить проверку частоты возможного ввода паролей. 3. Ограничить публичный доступ к страницам восстановления паролей.
Предотвращение обнаружения	В технике T1562 нарушители скрывают свою атаку, переназначая работу защитных средств.	1. Отключить функции проверки входа. 2. Сохранить логи HTTP-запросов к уязвимым скриптам. 3. Блокировать подозрительную активность с помощью брандмауэра.	1. Установить патчи для ПО, устраняющие уязвимости CVE-2024-2482 и CVE-2023-39343. 2. Провести аудит всех скриптов, которые могут быть уязвимы.

Продолжение таблицы Б2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Получение учётных данных	В технике T1110 атакующие применяют методы перебора для взлома данных и кражи учётных записей.	1. Отключить веб-сервис в пострадавших системах. 2. Сохранить логи аутентификации и попыток входа. 3. Включить мониторинг для поиска возможных массовых запросов логина.	1. Обновить mbCONNECT24 до версии 2.11.2 и выше, а также Ghost CMS до версии 5.9.5. 2. Добавить CAPTCHA на страницу входа, а также добавить таймер возможного ввода паролей. 3. Добавить многофакторную аутентификацию.
Перемещение внутри периметра	В технике T1021 нарушитель использует средства удалённых сервисов для перемещения внутри сети.	1. Отключить Cosmos-Server от сети. 2. Сохранить логи запросов к входу в систему. 3. Блокировать подозрительные HTTP-запросы с помощью брандмауэра.	1. Обновить RMS до версии 4.10.0 и Cosmos-Server до 0.17.7. 2. Ограничить доступ к административным учётным записям только для внутренних сетей.
Эксфильтрация данных	Для техники T1041 характерна маскировка трафика хищения данных под легитимный.	1. Остановить службы QRadar EDR и Antabot. 2. Сохранить и проанализировать все логи успехов и отказов для поиска уязвимостей. 3. Временно заблокировать все внешние подключения.	1. Установить обновления IBM QRadar EDR версии 3.12 и Antabot White-Jotter не менее версии 0.2.3. 2. Добавить использование шифрования канала.
Деструктивное воздействие	Под техникой T1486 подразумевают шифрование либо полное уничтожение данных на системах.	1. Отключить веб-интерфейс Cisco и перевести его в режим мониторинга. 2. Собрать логи аутентификации для подтверждения факта обхода защиты. 3. Блокировать попытки аутентификации с внешних сетей.	1. Установить обновление Cisco ECE версию выше 12.6, закрывающую уязвимость CVE-2022-20633. 2. Пересоздать учётные записи и ключи доступа.

Таблица Б3 – Организационные регламенты CAPEC-332

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Разведка	Техника T1595, используя уязвимость CVE-2025-30280, позволяет атакующему перечислять атрибуты приложений.	1. Включить анализ аномальных HTTP-запросов через брандмауэр. 2. Сохранить логи с подозрительными запросами.	1. Обновить Mendix Runtime до версии 10.21.0. 2. Добавить задержку на возможные действия на странице. 3. Сегментировать приложение для повышения безопасности.
Первоначальный доступ	В технике T1078 уязвимость CVE-2025-24023 позволяет при использовании определенного промежутка времени ответа выявить существующие логины. А техника T1190, реализуя свои уязвимости, позволяет перебирать логины.	1. Временно отключить веб-форму логина для невозможности продолжения атаки. 2. Сохранить логи попыток аутентификации и проанализировать временные промежутки.	1. Обновить Flask-AppBuilder до версии 4.5.3, а также применить выпущенные обновления IBM и Q-Free MaxTime. 2. Внедрить многофакторную аутентификацию и капчу на форму логина. 3. Добавить задержки для невозможности перебора паролей.
Закрепление	Техника T1574.002 используя уязвимость CVE-2021-37751, при загрузке неподписанных DLL может заразиться вредоносной библиотекой.	1. Немедленно выгрузить подозрительные DLL из процессов. 2. Сохранить логи загрузок библиотек.	1. Установить обновления ОС для защиты от неподписанных DLL файлов. 2. Провести проверку целостности и заменить подменённые файлы.
Предотвращение обнаружения	Уязвимости CVE-2023-49069 и CVE-2025-31124 отключают либо перенастраивают защиту.	1. Приостановить изменения средств защиты и зафиксировать их. 2. Сохранить логи API-запросов.	1. Загрузить обновления, ограничивающие права на изменение конфигурации защиты. 2. Пересоздать политики защиты с нуля.

Продолжение таблицы Б3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Обнаружение	Уязвимости CVE-2024-42343 и CVE-2025-46736 через запросы серверу, позволяют узнать полный список пользователей.	1. Блокировать подозрительные вызовы к конечным точкам. 2. Сохранить логи системных команд.	1. Установить патчи, что закрывают обе уязвимости.
Эксфильтрация данных	Техника T1041, реализуя уязвимости CVE-2025-2910 и CVE-2025-30150, позволяют получить конфиг сервиса.	1. Остановить рабочие службы и сохранить логи HTTP запросов. 2. Определить массовые последовательные запросы извлечения данных.	1. Обновить QRadar EDR до версии 3.12 и Antabot до версии 0.2.3 с исправленными уязвимостями. 2. Ввести ответы и задержку на каналы управления.
Деструктивное воздействие	Техника T1499 вызывает точечный отказ в обслуживании. Уязвимости, что она реализует: 1. CVE-2023-47159 приводит к вылету потока. 2. CVE-2024-56476 вызывает аварийное завершение процесса. 3. CVE-2025-23193 приводит к DoS через переполнение буфера.	1. Отфильтровать подозрительные запросы на уровне WAF/ACL. 2. Собрать дампы падений и логи отказов.	1. Применить патчи для устранения уязвимостей. 2. Ввести задержку и проверку размера пакетов.